

The Practitioner's Blueprint for Secure AI

By John M. Willis, Quantum Powered Security, Inc.



August 2025

Copyright and License

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc.

This manuscript is licensed under the Creative Commons Attribution 4.0 International License (CC BY 4.0). You are free to share and adapt this work for any purpose, including commercial use, provided appropriate attribution is given.

License: <https://creativecommons.org/licenses/by/4.0/>

Patent Notice

The concepts, architectures, and reference designs presented in this work are intended to encourage adoption, adaptation, and further innovation. Readers are encouraged to tailor PBSAI to their own environments, products, and services. Novel implementations, extensions, and improvements developed by others may be eligible for intellectual property protection under applicable patent laws.

The authors likewise reserve all rights to pursue patent protection for their own inventions, implementations, improvements, and future developments related to PBSAI. Certain aspects of this work are the subject of pending patent applications. Except as expressly stated by applicable law, no patent rights are granted or implied by this publication or its CC BY 4.0 license.

Volume 2: The Multi-Agent AI Defensive Cybersecurity Ecosystem

Domain B – Change Management

Table of Contents

Domain B - Asset, Configuration, and Change Management	5
B1. Asset Discovery Agent.....	5
Agent Blueprint [Informative]	5
Technical Implementation Details (B1) [Informative]	20
MCP-Native Protocol Specification (B1) [Normative]	22
B2. Baseline Compliance Agent	23
Agent Blueprint [Informative]	23
Technical Implementation Details (B2) [Informative]	37
MCP-Native Protocol Specification (B2) [Normative]	39
B3. Config Monitor Agent.....	40
Agent Blueprint [Informative]	40
Technical Implementation Details (B3) [Informative]	51
MCP-Native Protocol Specification (B3) [Normative]	53
B4. Change Governance Agent	54
Agent Blueprint [Informative]	54
Technical Implementation Details (B4) [Informative]	66
MCP-Native Protocol Specification (B4) [Normative]	69
B5. Patch Orchestration Agent	69
Agent Blueprint [Informative]	69
Technical Implementation Details (B5) [Informative]	85
MCP-Native Protocol Specification (B5) [Normative]	87
B6. Vulnerability Scanning Agent.....	88
Agent Blueprint [Informative]	88
Technical Implementation Details (B6) [Informative]	100
MCP-Native Protocol Specification (B6) [Normative]	103
B7. Risk Prioritization Agent	104
Agent Blueprint [Informative]	104
Technical Implementation Details (B7) [Informative]	111

MCP-Native Protocol Specification (B7) [Normative]	114
--	-----

Domain B - Asset, Configuration, and Change Management

B1. Asset Discovery Agent

Agent Blueprint [Informative]

Purpose: Build and maintain a real-time enterprise asset inventory across IT, OT, IoT, and cloud resources. Enrich asset records with classification, ownership, and exposure context for other agents. Runs on continuous discovery campaigns or on-demand missions (e.g., ransomware exposure mapping).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **Cloud Provider APIs (AWS, Azure, GCP, OCI):** compute/resource lists, NICs, public/private IPs, security groups, tags.
- **DHCP Lease Logs:** MAC↔IP mappings, lease start/expiry.
- **Active Directory / LDAP:** computer accounts, OU mapping, OS metadata, create timestamps.
- **EDR/AV Census REST/gRPC:** enrolled endpoints, sensor health, isolation state, last_seen.
- **Network Scanners (Nmap, Netdisco):** live hosts, open ports, service banners, L2/L3 topology.

Model training / knowledge (what the LLM relies on):

- **Normalization & ontology pack:** canonical **AssetRecord** schema (host, device, VM, container, function-as-a-service, DB, storage, network device, OT/IoT types).
- **Entity-resolution heuristics:** precedence rules across sources (e.g., cloud instanceId > EDR device_id > AD DN; DHCP used for IP-MAC binding corroboration).
- **RAG sources:** CMDB prior state, tagging dictionaries, OU ownership map, subnet→site map, internet egress map; never train on regulated logs—use evidence_refs.
- **Guardrails:** read-only in cloud/EDR; write-scoped tokens for CMDB only; **constraints** like no_auth_scan_in_prod enforced when present.

Decisions it makes (deterministic + model-assisted):

- **Identity resolution:** compute `asset_uid` from stable identifiers (cloud resource id, `device_id`, serial, MAC+hostname).
- **Asset class & criticality:** infer type (server, workstation, OT PLC, IoT camera), environment (prod/dev), and **classification** (C1 public metadata; C2 internal).
- **Ownership assignment:** resolve **owner_team** from tags, OU, EDR policy group; produce `ownership_confidence`.
- **Exposure determination:** detect **internet-facing** status (public IP, routable via egress, open ports) and compute `exposure_score`.
- **Lifecycle state:** active, dormant, decommission-candidate (e.g., AD stale + no EDR + DHCP absent N days).

Routing / where outputs go:

- **CMDB upserts** → create/update **AssetRecord** with provenance and confidence fields.
- **ASM ExposureRecord** → only for internet-facing or externally reachable assets.
- **AssetDiscoveryEvent** → Kafka/AMQP stream for downstream agents (Vuln, IR, IAM).
- **Tickets** → ownership conflicts, unenrolled endpoints, forbidden-scan violations.

Automation scope vs. manual/HITL:

- **Fully automated:** collection, normalization, identity resolution, enrichment, CMDB sync, exposure flagging.
- **HITL required:** ownership conflicts (confidence < theta), OT/IoT classification overrides, quarantine recommendations.
- **Manual outside agent:** approving discovery-scope exceptions; network change windows for authenticated scanning in prod OT.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **Cloud Provider APIs (AWS, Azure, GCP, OCI)** — enumerate resources, NICs, security groups
2. **DHCP Lease Logs** — MAC/IP bindings and lease events

3. **Active Directory / LDAP** — computer account inventory and attributes
4. **EDR/AV Census REST/gRPC** — endpoint enrollment/health census
5. **Network Scanners (Nmap, Netdisco)** — liveness, ports, L2/L3 context

Example: Consumed Protocol 1 — Cloud Provider APIs (AWS EC2 DescribeInstances) [Informative]

Native payload

```
{
  "InstanceId": "i-0abc123def4567890",
  "State": {"Name": "running"},
  "PrivateIpAddress": "10.12.34.56",
  "PublicIpAddress": "203.0.113.42",
  "Tags": [{"Key": "Owner", "Value": "app-team"}],
  "LaunchTime": "2025-08-14T17:45:00Z",
  "SecurityGroups": [{"GroupName": "web-sg"}]
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-aws-1111-2222-3333-4444",
    "thread_id": "uuid-cloud-ec2-aaa-bbb-ccc",
    "task_id": "uuid-5555-6666-7777-8888",
    "role": "AssetDiscoveryAgent",
    "intent": "discover",
    "policy_refs": ["CM-8", "NIST800-53-CM-8"],
    "decision_basis": {
      "evidence_refs": ["uri://aws/api/ec2/instance/i-0abc123def4567890"],

```

```

    "confidence": 1.0
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
    "signing_kid": "kid-aws-01",
    "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:aws01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 2 — DHCP Lease Logs [Informative]

Native payload

Aug 15 09:32:41 dhcp01 dhcpd: DHCPACK on 10.0.4.22 to 00:50:56:a1:b2:c3 via eth0

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-dhcp-2222-3333-4444-5555",
    "thread_id": "uuid-dhcp-aaa-bbb-ccc",
    "task_id": "uuid-6666-7777-8888-9999",
    "role": "AssetDiscoveryAgent",
    "intent": "discover",
    "policy_refs": ["CM-8"],
    "decision_basis": {
      "evidence_refs": ["uri://dhcp/logs/2025-08-15T09:32:41Z"],

```



```

    "confidence": 0.98
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
    "signing_kid": "kid-dhcp-02",
    "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:dhcp02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": "Aug 15 09:32:41 dhcp01 dhcpd: DHCPACK on 10.0.4.22 to
00:50:56:a1:b2:c3 via eth0"
}

```

Example: Consumed Protocol 3 — Active Directory / LDAP [Informative]

Native payload

dn: CN=HOST-SERVER01,OU=Servers,DC=corp,DC=example,DC=com

objectClass: computer

operatingSystem: Windows Server 2022 Standard

operatingSystemVersion: 10.0 (20348)

whenCreated: 20240812091530.0Z

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-ad-3333-4444-5555-6666",
    "thread_id": "uuid-adldap-aaa-bbb-ccc",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
  }
}

```

```

"role": "AssetDiscoveryAgent",
"intent": "discover",
"policy_refs": ["CM-8"],
"decision_basis": {
  "evidence_refs": ["uri://ldap/cn=HOST-
SERVER01,ou=Servers,dc=corp,dc=example,dc=com"],
  "confidence": 0.96
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
  "signing_kid": "kid-ad-03",
  "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:ad03"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": "dn: CN=HOST-
SERVER01,OU=Servers,DC=corp,DC=example,DC=com\nobjectClass:
computer\noperatingSystem: Windows Server 2022
Standard\noperatingSystemVersion: 10.0 (20348)\nwhenCreated: 20240812091530.0Z"
}

```

Example: Consumed Protocol 4 — EDR/AV Census REST/gRPC [Informative]
Native payload

```

{
  "device_id": "edr-7f3c2a91",
  "hostname": "srv-001",
  "platform": "windows",
  "os_version": "Windows Server 2022 20348.2402",
  "sensor_version": "7.2.15",

```

```

"policy_name": "Prod-Servers",
"endpoint_status": "healthy",
"tamper_protection": true,
"disk_encryption": "BitLocker",
"last_seen": "2025-08-15T11:12:05Z",
"ip_addresses": ["10.2.14.5"],
"mac_addresses": ["00:50:56:A1:B2:C3"],
"isolation_state": "not_isolated",
"av_engine": "Microsoft Defender",
"av_dat_version": "1.389.1420.0"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-edr-4444-5555-6666-7777",
    "thread_id": "uuid-edr-census-aaa-bbb-ccc",
    "task_id": "uuid-1212-3434-5656-7878",
    "role": "AssetDiscoveryAgent",
    "intent": "discover",
    "policy_refs": ["CM-8", "SI-3"],
    "decision_basis": {
      "evidence_refs": ["uri://edr/api/devices/edr-7f3c2a91"],
      "confidence": 0.99,
      "explanation_ref": "uri://kb/asset-discovery/edr-census-ingest"
    },
    "provenance": {

```

```

    "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
    "signing_kid": "kid-edr-04",
    "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:edr04"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { ... }
}

```

Example: Consumed Protocol 5 — Network Scanners (Nmap, Netdisco)

[Informative]

Native payload (Nmap XML)

```

<nmaprun scanner="nmap" args="nmap -sS -p 22,80,443 10.0.4.22"
start="1723717800">

```

```

  <host>
    <status state="up"/>
    <address addr="10.0.4.22" addrtype="ipv4"/>
    <hostnames><hostname name="srv-001"/></hostnames>
    <ports>
      <port protocol="tcp" portid="22">
        <state state="open"/>
        <service name="ssh" product="OpenSSH" version="9.2p1"/>
      </port>
      <port protocol="tcp" portid="443">
        <state state="open"/>
        <service name="https" product="nginx" version="1.25.2"/>
      </port>
    </ports>
  </host>

```

```

</host>
</nmaprun>
MCP-wrapped payload (Nmap)
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-nmap-8888-9999-aaaa-bbbb",
    "thread_id": "uuid-nmap-scan-10-0-4-22",
    "task_id": "uuid-0a0a-1b1b-2c2c-3d3d",
    "role": "AssetDiscoveryAgent",
    "intent": "discover",
    "policy_refs": ["CM-8", "CA-7"],
    "constraints": ["no_auth_scan_in_prod"],
    "decision_basis": {
      "evidence_refs": ["uri://nmap/xml/scan/10.0.4.22/2025-08-15T10:30:00Z"],
      "confidence": 0.94
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
      "signing_kid": "kid-nmap-05",
      "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:nmap05"
    },
    "classification": "C1",
    "legal_hold": false
  },
  "native_payload": "<nmaprun ...>...</nmaprun>"
}

```

Native payload (Netdisco JSON) and MCP-wrapped payload

```
{
  "ip": "10.0.4.22",
  "mac": "00:50:56:A1:B2:C3",
  "vendor": "VMware",
  "device_name": "srv-001",
  "ports": [
    {"port": "eth0", "vlan": 20, "speed_mbps": 1000, "duplex": "full"},
    {"port": "eth1", "vlan": 443, "speed_mbps": 1000, "duplex": "full"}
  ],
  "first_seen": "2025-08-14T18:02:10Z",
  "last_seen": "2025-08-15T11:10:55Z"
}

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-assetdisc-netdisco-bbbb-cccc-dddd-eeee",
    "thread_id": "uuid-netdisco-10-0-4-22",
    "task_id": "uuid-4e4e-5f5f-6a6a-7b7b",
    "role": "AssetDiscoveryAgent",
    "intent": "discover",
    "policy_refs": ["CM-8"],
    "decision_basis": {
      "evidence_refs": ["uri://netdisco/devices/10.0.4.22/snapshots/2025-08-15T11:10:55Z"],
      "confidence": 0.96
    }
  },
}
```

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```

"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/asset-discovery-agent",
  "signing_kid": "kid-netdisco-06",
  "attestation_ref": "uri://slsa/attestations/asset-discovery@sha256:netdisco06"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { ... }
}

```

Outputs (native) [Informative]

- **CMDB AssetRecord** create/update (REST/GraphQL).
- **ASM ExposureRecord** for internet-facing assets.
- **Kafka/AMQP AssetDiscoveryEvent** for downstream consumers.

MCP context (required) [Informative]

mission_id; role="AssetDiscoveryAgent"; intent="discover"; campaign_id; policy_refs (inventory completeness standards); decision_basis (source systems, scan ranges); provenance (SPIFFE ID, signing key, attestation)

MCP context (optional) [Informative]

constraints (e.g., "no_auth_scan_in_prod"); classification (C1 public, C2 internal); legal_hold

Enforcement note [Informative]

CMDB/ASM receivers must verify **provenance.attestation** and reject writes lacking authorized SPIFFE identity or with stale signatures; scanning **constraints** must be honored by orchestrators.

NIST SP 800-160v2 linkage [Informative]

Establish Context & Maintain Awareness — resilient operations require current asset visibility foundation.

Automation feasibility [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Full: discovery, enrichment, CMDB sync automatable; scope exceptions and OT authenticated scans require HITL.

Output Contracts (merged) [Informative]

OC-1: AssetRecordUpsert (CMDB) [Informative]

- **Producer(s):** B1
- **Topic/Path:** POST /cmdb/api/asset or GraphQL mutation upsertAssetRecord
- **Schema/Format:** AssetRecord@1.2 (canonical) with fields: asset_uid, identifiers{cloud_id, device_id, serial, mac[], hostname}, ips[], owner_team, env, class, tags{}, exposure_flags, provenance, confidence_metrics
- **Classification:** C2 (metadata)
- **Delivery:** at-least-once
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(asset_uid, updated_at_floor_60s)
- **Ack/Nack:** HTTP 200/201 ACK; 4xx/5xx NACK
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x; dead-letter to ticket on persistent NACK
- **Side-Effects:** CMDB change log append; ownership notification if owner changed
- **HITL Token:** required when owner change would flip privileged system ownership
- **Observability:** trace_id, mission_id, campaign_id, decision_basis.evidence_refs, classification_label, provenance.attestation
- **Retention/TTL:** CMDB policy (>= 7 years audit log)

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=AssetRecord@1.2 | json_schema_uri=uri://schema/asset-record-1.2.json | sha256= | producers=B1 | consumers=CMDB-01 | accepts=1.0–1.2 (1.0 EOL 2026-12-31)

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: ASME ExposureRecord (Internet-Facing) [Informative]

- **Producer(s):** B1
- **Topic/Path:** POST /asm/api/exposures
- **Schema/Format:** ExposureRecord@1.0 with fields: asset_uid, public_ip, fqdn[], ports[], tls_info, exposure_score, first_seen, last_seen, evidence_refs[]
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(asset_uid, public_ip, port_set_hash)
- **Ack/Nack:** 201 Created; 409 conflict → treat as ACK and update last_seen
- **Timeouts/Retry:** ack<=30s; exp-backoff<=5x
- **Side-Effects:** notify ASM; trigger vuln scan if policy mandates
- **HITL Token:** optional; required if exposure_score >= theta_critical and auto-quarantine requested
- **Observability:** trace_id, mission_id, decision_basis, exposure_score, provenance
- **Retention/TTL:** >= 2 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When ASM/external exposure management is enabled OR internet-facing assets detected

schema_id=ExposureRecord@1.0 | json_schema_uri=uri://schema/exposure-record-1.0.json | sha256= | producers=B1 | consumers=ASM-01 | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: AssetDiscoveryEvent (Stream) [Informative]

- **Producer(s):** B1
- **Topic/Path:** kafka://sec.assets.discovery.v1 or AMQP equivalent

- **Schema/Format:** AssetDiscoveryEvent@1.0 (event types: created|updated|ownership_change|exposure_change|decommission_candidate)
- **Classification:** C1 (headers) + C2 (payload)
- **Delivery:** at-least-once (consumers dedupe on event_id)
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(event_id)
- **Ack/Nack:** broker ACK; NACK dead-letters
- **Timeouts/Retry:** broker-configured; producer retry<=5x
- **Side-Effects:** downstream triggers (vuln scan, IR enrichment, IAM review)
- **HITL Token:** none (events informational)
- **Observability:** trace_id, mission_id, campaign_id, classification_label, provenance
- **Retention/TTL:** broker retention policy (>= 30 days recommended)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When a messaging bus is present and downstream agents subscribe
 schema_id=AssetDiscoveryEvent@1.0 | json_schema_uri=uri://schema/asset-discovery-event-1.0.json | sha256= | producers=B1 | consumers={Vuln-01, IR-01, IAM-01} | accepts=1.0–1.x

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, normalizing, correlating, enriching, publishing, streaming, exclusion_review, failed, closed }

transition(idle -> ingesting) when campaign started OR on-demand mission received

transition(ingesting -> normalizing) when batch/window collected

transition(normalizing -> correlating) when schema normalized and identifiers extracted

transition(correlating -> enriching) when asset_uid resolved

transition(enriching -> publishing) when ownership/exposure computed

transition(publishing -> streaming) when CMDB/ASM ACKs received

transition(correlating -> exclusion_review) when constraints violated (e.g.,
no_auth_scan_in_prod)

transition(* -> failed) on validation error or timeouts

timeout(publishing, 30s) -> retry<=5 -> failed

idempotency_key(AssetRecordUpsert) = sha256(asset_uid, updated_at_floor_60s)

idempotency_key(ExposureRecord) = sha256(asset_uid, public_ip, port_set_hash)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 AssetRecordUpsert	Required	Always	System of record for assets
OC-2 ASMExposureRecord	Conditionally Required	ASM enabled OR internet-facing assets detected	Exposure management & risk reduction
OC-3 AssetDiscoveryEvent	Conditionally Required	Messaging bus present with subscribing downstream agents	Near-real-time automation fan-out

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** CM-8, CA-7, AU-12 (logging of discovery), internal inventory SLAs.
- **HITL required:** ownership_confidence < theta_low; OT/IoT class override; auto-quarantine proposals.

- **Automatic HITL escalation:** model_drift_detected; spike in internet-facing counts; forbidden-scan violation.

SLOs and KPIs [Informative]

- **CMDBUpsertAck_p95** <= 30 s
- **Coverage_CM-8** >= 98 percent of in-scope subnets and accounts (rolling 30d)
- **UnownedAssets_7d** <= 1 percent
- **ExposureDetection_MTTD** <= 15 min
- **DuplicateAssetRate_30d** <= 0.5 percent

Outputs index [Informative]

[OC-1 AssetRecordUpsert], [OC-2 ASMEExposureRecord], [OC-3 AssetDiscoveryEvent]

Technical Implementation Details (B1) [Informative]

Model and training profile [Informative]

model_id=entity-resolution-model; temperature=0.0; max_tokens_out=300
 prompt_pack_id=asset-normalization-v1 (ontology + precedence rules)
 RAG: sources={cmdb-historical, cloud-tag-dict, subnet-site-map, ou-owner-map};
 max_docs=12; min_similarity=0.80; citations required
 fine_tuning/adapters: none initially; evaluate on match-precision/recall and ownership assignment accuracy
 guardrails: read scopes for sources; write scope only to CMDB/ASM; enforce constraints list

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency
 episodic_memory: per mission_id & campaign_id journal; ttl=365d
 semantic_memory: namespaces=["assets","ownership","subnets"]; embeddings=text-embedding-sec-v1; k=12
 durable_state_store: event-sourced ledger of asset_uid changes; snapshot daily
 consistency: at-least-once (publish/stream) with consumer de-dupe
 idempotency: as per Output Contracts

Decision and routing logic [Informative]

asset_uid = prefer_first_nonnull([cloud.resource_id, edr.device_id, serial])

else sha256(lower(hostname), mac_primary)

ownership_confidence = 0.45*tag_owner_signal + 0.25*ou_mapping_signal
+ 0.20*edr_policy_signal + 0.10*ticket_history_signal

exposure_score = 0.5*public_ip_flag + 0.2*open_port_weighted
+ 0.2*service_banner_risk + 0.1*geo_routing_risk

routing: CMDDB upsert → ASM exposure (if applicable) → event stream fan-out.

Model Risk Management [Informative]

continuous_validation: daily labeled pairs for entity resolution; jailbreak/adversarial inputs blocked (no free-text actions)

thresholds: match_precision_7d >= 99.5 percent; auto_HITL if below

red_team_cycle: monthly seeded duplicates and spoofed identifiers

rollback_policy: revert precedence ruleset if drift > 1 percentage point for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: identifiers considered; weights; evidence_refs; computed confidences

UI/API fields: classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; include asset_uid, change_set, before/after, signature hashes

Incident Response Integration [Informative]

emit AssetDiscoveryEvent on exposure_change; map severity for SIEM correlation; attach evidence_refs (Nmap/Cloud/EDR)

Data Sovereignty and Legal Hold [Informative]

data_locality_policy: region-aware ingestion; DHCP/scan logs remain regional;

legal_hold=true → retain raw logs indefinitely

Interfaces (links only) [Informative]

Consumes: Cloud APIs; DHCP logs; AD/LDAP; EDR/AV Census; Nmap/Netdisco

Produces: OC-1 AssetRecordUpsert; OC-2 ASME ExposureRecord; OC-3

AssetDiscoveryEvent

Safety and abuse prevention [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

kill_switch if write spike > threshold or provenance check fails; enforce constraints (e.g., block auth scans in prod)
blast_radius caps: <= N upserts/minute per namespace when confidence < theta_med

Testing and validation [Informative]

contract tests for each OC; synthetic dupes; reconciliation with gold CMDB snapshot; exposure detection golden set

Deployment and lifecycle [Informative]

horizontal scaling by account/subnet shard; canary per cloud account; SBOM + attestations; signed outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2 (Cyber-Resiliency Engineering)
NIST SP 800-53 Rev. 5 **CM-8** (Information System Component Inventory), **CA-7** (Continuous Monitoring), **AU-12** (Audit)
NIST SP 800-137 (Information Security Continuous Monitoring)
NIST SP 800-115 (Technical Guide to Information Security Testing and Assessment)
NIST CSF 2.0 (ID.AM Asset Management; DE.CM Continuous Monitoring)
CIS Controls v8 (C1: Inventory of Enterprise Assets; C2: Inventory of Software Assets)

MCP-Native Protocol Specification (B1) [Normative]

- **Native Protocol(s) Consumed:** Cloud Provider APIs; DHCP Lease Logs; Active Directory/LDAP; EDR/AV Census REST/gRPC; Network Scanners (Nmap, Netdisco)
- **Native Protocol(s) Produced:** CMDB AssetRecord (REST/GraphQL); ASM ExposureRecord; Kafka/AMQP AssetDiscoveryEvent
- **MCP Context Fields:**
 - **Required:** mission_id; role="AssetDiscoveryAgent"; intent="discover"; campaign_id; policy_refs; decision_basis; provenance (SPIFFE ID, KID, attestation)
 - **Optional:** constraints; classification; legal_hold
- **Enforcement Note:** Receivers MUST verify provenance.attestation and authorized SPIFFE identity; orchestrators MUST enforce declared constraints (e.g., no_auth_scan_in_prod).

- **Versioning & compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative above).
- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` available to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

B2. Baseline Compliance Agent

Agent Blueprint [Informative]

Purpose: Evaluate hosts and services against CIS, NIST, and organizational baselines; produce findings and proposed enforcement plans (config deltas).

Operational Narrative [Informative]

Inputs used (authoritative sources):

- Git (desired state baselines): YAML/JSON benchmark profiles, mapping to CIS/NIST/internal controls.
- Ansible/Chef/Puppet facts: current config snapshots for managed nodes.
- Windows DSC / LGPO / GPO export: Windows baseline state and drift.
- Kubernetes API / OPA Gatekeeper audit: cluster/workload conformance snapshots.
- CMDB Baseline Records (REST/GraphQL): authoritative baseline config bindings per CI and asset group; baseline version pointer; snapshot hashes for attestation.
- CIS/NIST Hardening Benchmarks (REST/OCI/Registry): canonical benchmark definitions and versions referenced by desired state.

Model training / knowledge (what the LLM relies on):

- Baseline ontology + rule DSL: canonical representation of checks, resources, and expected values.
- Mapping library: CIS/NIST 800-53 linkage (e.g., CM-6), internal baseline IDs, exception policies.
- RAG sources: baseline repo history, golden host profiles, change-impact heuristics; do not train on regulated logs—use `evidence_refs`.

- Guardrails: read-only on prod nodes; writing limited to PRs or non-prod ConfigSets; enforce constraints=["no-prod-without-2-approvals","attested_evidence_required:true"].

Decisions it makes (deterministic + model-assisted):

- Compliance evaluation: join desired state to observed state, compute pass/fail per rule, and aggregate by asset, service, and environment.
- Drift detection: compute $\text{group_drift_rate} = \text{noncompliant_assets} / \text{total_assets}$ per CMDB asset group; alert when $\text{group_drift_rate} > 0.05$; raise priority when week-over-week drift delta exceeds threshold.
- Remediation planning: generate minimal config deltas and pick delivery path (PR vs. ConfigSet) per environment and constraint.
- Risk-aware gating: raise HITL when blast_radius or service_impact exceeds thresholds, or when in-scope is prod without dual approvals.
- Classification: default C2; elevate to C3 for payloads including sensitive pathing or admin credential references.

Routing / where outputs go:

- BaselineFinding events → Kafka/AMQP for downstream consumers (IR, Risk, Platform).
- EnforcementPlan → either Git PR against baseline/config repo or a ConfigSet for Ansible/Puppet/Chef in staging; production requires approvals.
- ComplianceSummary (per asset group) → REST/GraphQL or Kafka.
- BaselineDriftReport (auditor package) → artifact store with link via event.

Automation scope vs. manual/HITL:

- Fully automated: evaluation, diff creation, PR generation for non-prod, ConfigSet for staging.
- HITL required: any prod enforcement; any change with $\text{change_risk} \geq 0.7$; K8s policies that could cause pod eviction; Windows GPOs affecting domain-wide settings.
- Manual outside agent: acceptance of new baseline families, policy arbitration, emergency freezes during change moratoriums.

Security Domain: Asset, Configuration, and Change Management

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Inputs (native protocols consumed) [Informative]

1. Git over HTTPS/SSH — “desired state” baseline definitions (YAML/JSON)
2. Ansible/Chef/Puppet Facts (REST/SSH/HTTPS) — current config snapshots
3. Windows DSC / LGPO / GPO Export (REST/WinRM/SMB) — Windows baseline state snapshot
4. Kubernetes API / OPA Gatekeeper Audit (HTTPS) — cluster/workload policy conformance
5. CMDB Baseline Records (ServiceNow/Archer/Custom REST/GraphQL) — authoritative baseline per CI/asset group; snapshot_hash and exception links
6. CIS/NIST Benchmark Registry (REST/OCI/JSON) — canonical benchmark definitions and versions

Example: Consumed Protocol 1 — Git (desired state baselines) [Informative]

Native payload

id: cis_linux_1_0_0

version: "1.0.0"

title: "CIS Linux Level 1"

rules:

- id: cis-1.1.1

resource: "fs.mounts"

check: "nodev_on_/tmp"

expected: true

- id: cis-5.2.15

resource: "ssh.server"

check: "log_level"

expected: "VERBOSE"

metadata:

owners: ["sec.baselines"]

applies_to: ["linux"]

MCP-wrapped payload

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b2-git-1111-2222-3333-4444",
    "thread_id": "uuid-b2-desired-state-cis-linux",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
    "role": "BaselineComplianceAgent",
    "intent": "assess",
    "policy_refs": ["CIS-Linux-L1-1.0.0", "800-53 CM-6"],
    "constraints": ["no-prod-without-2-approvals", "attested_evidence_required:true"],
    "decision_basis": {
      "evidence_refs": ["uri://git/sec/baselines/cis_linux_1_0_0.yaml@v1.0.0"],
      "confidence": 1.0,
      "explanation_ref": "uri://kb/baselines/cis-linux-l1"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/baseline-compliance-agent",
      "signing_kid": "kid-git-b2-01",
      "attestation_ref": "uri://slsa/attestations/baseline-compliance@sha256:git01"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": "id: cis_linux_1_0_0\nversion: \"1.0.0\"...\n"
}
```

Example: Consumed Protocol 2 — Ansible/Chef/Puppet Facts [Informative]

Native payload

```
{
  "ansible_facts": {
    "ansible_hostname": "srv-001",
    "ansible_distribution": "Ubuntu",
    "ansible_distribution_version": "22.04",
    "ansible_mounts": [
      {"mount": "/tmp", "options": "rw,nosuid,nodev,noexec"}
    ],
    "sshd_config": {"LogLevel": "INFO","PermitRootLogin": "no"}
  },
  "collected_at": "2025-08-15T10:42:10Z",
  "inventory_group": "linux-prod"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b2-facts-2222-3333-4444-5555",
    "thread_id": "uuid-ansible-facts-srv-001",
    "task_id": "uuid-eeee-ffff-1111-2222",
    "role": "BaselineComplianceAgent",
    "intent": "assess",
    "policy_refs": ["CIS-Linux-L1-1.0.0", "800-53 CM-6"],
    "constraints": ["no-prod-without-2-approvals","attested_evidence_required:true"],
    "decision_basis": {
      "evidence_refs": ["uri://ansible/facts/srv-001/2025-08-15T10:42:10Z"],
      "confidence": 0.98
    }
  }
}
```

```

    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/baseline-compliance-agent",
      "signing_kid": "kid-ansible-b2-02",
      "attestation_ref": "uri://slsa/attestations/baseline-compliance@sha256:ans02"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 3 — Windows DSC / LGPO / GPO Export **[Informative]**

Native payload

```

{
  "NodeName": "WIN-SRV-02",
  "LCMVersion": "2.0",
  "StartDate": "2025-08-15T10:05:00Z",
  "ResourcesInDesiredState": [{"ResourceName":
"LGPO", "InstanceName": "AuditPolicy:LogonEvents"}],
  "ResourcesNotInDesiredState": [{"ResourceName":
"LGPO", "InstanceName": "AuditPolicy:ProcessCreation", "Current": "Disabled", "Desired": "
Enabled"}]
}

```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b2-dsc-3333-4444-5555-6666",

```

```

"thread_id": "uuid-dsc-WIN-SRV-02",
"task_id": "uuid-9999-0000-aaaa-bbbb",
"role": "BaselineComplianceAgent",
"intent": "assess",
"policy_refs": ["CIS-Windows-L1-2.0.0", "800-53 AU-12", "CM-6"],
"constraints": ["no-prod-without-2-approvals", "attested_evidence_required:true"],
"decision_basis": {
  "evidence_refs": ["uri://win/dsc/reports/WIN-SRV-02/2025-08-15T10:05:00Z"],
  "confidence": 0.97
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/baseline-compliance-agent",
  "signing_kid": "kid-dsc-b2-03",
  "attestation_ref": "uri://slsa/attestations/baseline-compliance@sha256:dsc03"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 4 — Kubernetes API / OPA Gatekeeper Audit

[Informative]

Native payload

```

{
  "constraint": "require-seccomp",
  "kind": "Pod",
  "namespace": "payments",

```

```

"name": "svc-api-7f9c8f",
"violation": "containers must set securityContext.seccompProfile",
"timestamp": "2025-08-15T11:20:45Z"
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b2-k8s-4444-5555-6666-7777",
    "thread_id": "uuid-gatekeeper-payments",
    "task_id": "uuid-cccc-dddd-eeee-ffff",
    "role": "BaselineComplianceAgent",
    "intent": "assess",
    "policy_refs": ["K8S-SEC-BL-1.1", "800-53 CM-6", "CIS-Kubernetes-1.7"],
    "constraints": ["no-prod-without-2-approvals", "attested_evidence_required:true"],
    "decision_basis": {
      "evidence_refs": ["uri://k8s/gatekeeper/audit/payments/svc-api-7f9c8f/2025-08-15T11:20:45Z"],
      "confidence": 0.95
    },
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/baseline-compliance-agent",
    "signing_kid": "kid-k8s-b2-04",
    "attestation_ref": "uri://slsa/attestations/baseline-compliance@sha256:k8s04"
  },
  "classification": "C2",
  "legal_hold": false
}

```

```
},  
"native_payload": { "...": "..." }  
}
```

Outputs (native) [Informative]

- BaselineFinding (Kafka/AMQP) with per-asset and per-rule results.
- EnforcementPlan (Git PR or ConfigSet to Ansible/Puppet/Chef) with proposed deltas.
- ComplianceSummary (per asset group compliance %) via REST/GraphQL or Kafka.
- BaselineDriftReport (auditor-ready PDF/JSON bundle with rollups, trends, and evidence links).

MCP context (required) [Informative]

mission_id; role="BaselineComplianceAgent"; intent="assess"; policy_refs (baseline IDs; CIS/NIST mappings); constraints=["no-prod-without-2-approvals", "attested_evidence_required:true"]; provenance (SPIFFE ID, signing key, attestation)

MCP context (optional) [Informative]

classification (usually C2); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs for CI/CD and config orchestrators MUST enforce constraints=["no-prod-without-2-approvals", "attested_evidence_required:true"]. Production enforcement requires dual approvals and signed provenance. A rule pass (status=pass) MUST ONLY be declared when the observed config snapshot hash is present and attested (evidence_attestation valid) and matches the finding's observed_hash.

NIST SP 800-160v2 linkage [Informative]

Develop & Implement (encode requirements as configuration) and Evaluate (verify conformance) underpin resilient system posture.

Automation feasibility [Informative]

High: evaluation and plan generation are automatable; production enforcement is approval-gated.

Output Contracts (merged) [Informative]

OC-1: BaselineFinding (Event) [Informative]

- **Producer(s):** B2
- **Topic/Path:** kafka://sec.baselines.findings.v1 (or AMQP equivalent)
- **Schema/Format:** BaselineFinding@1.1 with fields: finding_id, asset_uid, rule_id, desired, observed, status{pass|fail|error|skip}, severity, remediation_suggested, evidence_refs[], policy_refs[], classification_label, provenance, observed_hash, evidence_attestation
- **Classification:** C2
- **Delivery:** at-least-once (consumers dedupe on finding_id)
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(asset_uid, rule_id, observed_hash)
- **Ack/Nack:** broker ACK; NACK to dead-letter
- **Timeouts/Retry:** broker-configured; producer retry<=5x
- **Side-Effects:** may open ticket when severity >= high and auto-remediation disabled
- **HITL Token:** none (event only)
- **Observability:** trace_id, mission_id, decision_basis, severity, provenance.attestation
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=BaselineFinding@1.1 | json_schema_uri=uri://schema/baseline-finding-1.1.json | sha256= | producers=B2 | consumers={IR-01,Risk-01,Platform-01} | accepts=1.0–1.1

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: EnforcementPlan (PR or ConfigSet) [Informative]

- **Producer(s):** B2
- **Topic/Path:** Git PR to sec/baselines or infra/config; OR POST /orchestrator/configset
- **Schema/Format:** EnforcementPlan@1.0 with fields: plan_id, target_scope, env, deltas[], blast_radius_score, change_risk, approvals_required, rollback_plan_ref, evidence_refs[], policy_refs[], classification_label, provenance
- **Classification:** C2 (may escalate to C3 if secrets or sensitive paths referenced)
- **Delivery:** exactly-once per plan_id (receivers enforce idempotency)
- **Ordering:** per-target_scope
- **Idempotency-Key:** sha256(plan_id)
- **Ack/Nack:** PR number or 201 Created; NACK on policy or validation failure
- **Timeouts/Retry:** ack<=60s; retry<=5 with exp backoff; on failure open ticket and mark pending
- **Side-Effects:** open approvals workflow; attach diffs and test plan; schedule staging canary
- **HITL Token:** required for env=prod or change_risk >= 0.7
- **Observability:** trace_id, mission_id, change_risk, blast_radius_score, provenance.attestation
- **Retention/TTL:** >= 7 years (audit trail)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When enforcement path is enabled OR non-prod remediation is permitted; always in prod after approvals

schema_id=EnforcementPlan@1.0 | json_schema_uri=uri://schema/enforcement-plan-1.0.json | sha256= | producers=B2 | consumers={Git-01,Ansible-01,Puppet-01,Chef-01} | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-3: ComplianceSummary (Per-Group Rollup) [Informative]

- **Producer(s):** B2
- **Endpoint/Path:** POST /compliance/summary or topic sec.baselines.compliance.summary.v1

- **Schema/Format:** ComplianceSummary@1.0 with fields: group_id, baseline_id, window_start, window_end, total_assets, compliant_assets, noncompliant_assets, compliance_percent, drift_rate, evidence_refs[], policy_refs[], provenance
- **Classification:** C1–C2
- **Delivery:** exactly-once per (group_id, window)
- **Ordering:** per-group_id
- **Idempotency-Key:** sha256(group_id, window_start, window_end, baseline_id)
- **Ack/Nack:** 201 or broker ACK
- **Timeouts/Retry:** ack<=30s; retry<=5
- **Side-Effects:** updates exec/auditor dashboards
- **HITL Token:** none
- **Observability:** trace_id, mission_id, classification_label, provenance.attestation
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When CMDB asset groups are defined

schema_id=ComplianceSummary@1.0 | json_schema_uri=uri://schema/compliance-summary-1.0.json | sha256= | producers=B2 | consumers={ExecDash-01,Audit-01} | accepts=1.0–1.x

Conformance: Normative when condition is met.

OC-4: BaselineDriftReport (Auditor Bundle) [Informative]

- **Producer(s):** B2
- **Endpoint/Path:** artifact s3://audit/baselines//drift-report-v1.json|pdf + event sec.baselines.drift.report.v1
- **Schema/Format:** BaselineDriftReport@1.0 with fields: report_id, period, groups[], drift_threshold, group_summaries[], evidence_pack_uri, signatures[], decision_rationale_url
- **Classification:** C2
- **Delivery:** at-least-once

- **Ordering:** per-period
- **Idempotency-Key:** sha256(report_id, period)
- **Ack/Nack:** artifact 201 + event ACK
- **Timeouts/Retry:** ack<=60s; retry<=5
- **Side-Effects:** notifies auditors; links to ComplianceSummary rows and evidence_refs
- **HITL Token:** required to waive drift beyond threshold without remediation plan
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When audit reporting is enabled OR drift_rate > threshold for any group in the period

schema_id=BaselineDriftReport@1.0 | json_schema_uri=uri://schema/baseline-drift-report-1.0.json | sha256= | producers=B2 | consumers={Audit-01,GRC-01} | accepts=1.0–1.x

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting_desired, ingesting_observed, ingesting_cmdb,
ingesting_benchmarks,
evaluating, computing_group_rollups, planning, submitting, awaiting_approval,
publishing, failed, closed }

transition(idle -> ingesting_desired) when baseline repo change detected

transition(ingesting_desired -> ingesting_cmdb) when desired parsed

transition(ingesting_cmdb -> ingesting_benchmarks) when CMDB bindings loaded

transition(ingesting_benchmarks -> ingesting_observed) when benchmark refs resolved

transition(ingesting_observed -> evaluating) when facts/DSC/GK audits arrive

transition(evaluating -> computing_group_rollups) when per-asset results ready

transition(computing_group_rollups -> publishing) after ComplianceSummary generated
 transition(evaluating -> planning) when failures detected
 transition(planning -> submitting) when plan generated and constraints checked
 transition(submitting -> awaiting_approval) when env=prod OR change_risk >= 0.7
 transition(submitting -> publishing) when env!=prod AND policy allows auto
 transition(* -> failed) on validation error or timeouts

timeout(submitting, 60s) -> retry<=5 -> failed

idempotency_key(BaselineFinding) = sha256(asset_uid, rule_id, observed_hash)

idempotency_key(EnforcementPlan) = sha256(plan_id)

idempotency_key(ComplianceSummary) = sha256(group_id, window_start, window_end, baseline_id)

idempotency_key(BaselineDriftReport) = sha256(report_id, period)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 BaselineFinding	Required	Always	Compliance evidence and visibility
OC-2 EnforcementPlan	Conditionally Required	Enforcement path enabled or non-prod remediation; prod after approvals	Baseline hardening at scale
OC-3 ComplianceSummary	Conditionally Required	CMDB asset groups defined	Exec/auditor rollups, KPI tracking
OC-4 BaselineDriftReport	Conditionally Required	Audit reporting enabled OR any group drift_rate > threshold	Auditor-ready drift evidence

Requirement Level Definitions:

- Required: Must be implemented for conformant deployment
 - Conditionally Required: Must be implemented when trigger condition is met
 - Optional: May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- policy_refs: CM-6, AU-12, CIS profiles, internal baselines.
- HITL required: env=prod; change_risk >= 0.7; blast_radius_score >= theta_high; Windows domain-wide GPO changes; waiving drift beyond threshold without plan.
- Manual outside agent: acceptance of new baselines; emergency freeze windows.

SLOs and KPIs [Informative]

- FindingPublishAck_p95 <= 30 s
- PlanSubmissionAck_p95 <= 60 s
- FalsePositiveFindingRate_30d <= 1 percent
- TimeToRemediate_50 for non-prod <= 24 h
- GroupDriftAlertLatency_p95 <= 5 min
- DriftRecurrence_30d <= 5 percent

Outputs index [Informative]

[OC-1 BaselineFinding], [OC-2 EnforcementPlan], [OC-3 ComplianceSummary], [OC-4 BaselineDriftReport]

Technical Implementation Details (B2) [Informative]

Model and training profile [Informative]

model_id=baseline-eval-model; temperature=0.0; max_tokens_out=400
prompt_pack_id=baseline-rubric-v1 (rule DSL + mapping)
RAG: sources={baseline repo, golden profiles, exceptions registry, CMDB bindings, CIS/NIST registry}; max_docs=12; min_similarity=0.80; citations required
fine_tuning/adapters: none initially; eval on rule-eval accuracy and delta minimality

guardrails: prod writes disabled; only PRs with signed provenance allowed; must verify attested evidence (observed_hash + evidence_attestation) for any pass decision

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency_then_importance
episodic_memory: per mission_id journal of evaluations and plans; ttl=365d
semantic_memory:
namespaces=["baselines","exceptions","goldens","cmdb","benchmarks"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: event-sourced findings ledger; daily snapshots
consistency: at-least-once (findings); exactly-once (plans per plan_id)
idempotency: per Output Contracts

Decision and routing logic [Informative]

rule_status = pass if (observed == expected) and (evidence_attestation_valid == true)
else fail
group_drift_rate = noncompliant_assets / total_assets
alert_drift = (group_drift_rate > 0.05)
change_risk = 0.4blast_radius + 0.3service_impact + 0.2*(1 - evidence_confidence) + 0.1*churn_rate
auto_enforce = (env != "prod") and (change_risk < 0.7) and policy_allows_auto
routing: findings→stream; if fail and auto_enforce true→ConfigSet; else→PR and approvals; publish ComplianceSummary each window; emit BaselineDriftReport when alert_drift or at audit window.

Model Risk Management [Informative]

continuous_validation: daily golden hosts; adversarial inputs for malformed configs
thresholds: eval_pass_rate >= 99.5 percent → auto_HITL if below
red_team_cycle: monthly K8s/GPO policy edge cases
rollback_policy: revert ruleset or model if drift >= 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: rule, expected vs observed, delta summary, risk scores, observed_hash, evidence_attestation, evidence_refs, policy_refs
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL; stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

send high-severity findings to SIEM correlation; tag assets with baseline noncompliance for IR triage; emit drift alerts to SOC when alert_drift == true

Change Impact Assessment [Informative]

compute change_risk and blast_radius; gate plans and approvals accordingly

Stakeholder Feedback Loop [Informative]

collect reviewer labels on findings and plans; queue for rubric updates after governance review

Data Sovereignty and Legal Hold [Informative]

respect regional residency for facts/DSC exports; legal_hold=true → override TTL

Interfaces (links only) [Informative]

Consumes: Git baselines; Ansible/Chef/Puppet facts; Windows DSC/LGPO/GPO export; K8s/OPA audit; CMDB Baseline Records; CIS/NIST Benchmark Registry

Produces: OC-1 BaselineFinding; OC-2 EnforcementPlan; OC-3 ComplianceSummary; OC-4 BaselineDriftReport

Safety and abuse prevention [Informative]

kill_switch on anomalous plan volume or missing provenance; caps on concurrent prod PRs; deny pass decisions without evidence attestation

Testing and validation [Informative]

contract tests for all OCs; replay evaluations on gold datasets; regression on delta minimality; unit tests for drift_rate thresholds and attestation checking

Deployment and lifecycle [Informative]

scale by inventory shard; canary rule-packs; SBOM + attestations; sign outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, AU-12); NIST SP 800-137; CIS Benchmarks; NIST CSF 2.0 (PR.IP, DE.CM); ISO/IEC 27002:2022

MCP-Native Protocol Specification (B2) [Normative]

- **Native Protocol(s) Consumed:** Git baselines; Ansible/Chef/Puppet facts; Windows DSC/LGPO/GPO export; Kubernetes API / OPA Gatekeeper audit; CMDB Baseline Records (REST/GraphQL); CIS/NIST Benchmark Registry (REST/OCI)

- **Native Protocol(s) Produced:** BaselineFinding (Kafka/AMQP); EnforcementPlan (Git PR or ConfigSet); ComplianceSummary (REST/Kafka); BaselineDriftReport (artifact + event)
- **MCP Context Fields:**
 - Required: mission_id; role="BaselineComplianceAgent"; intent="assess"; policy_refs; constraints=["no-prod-without-2-approvals","attested_evidence_required:true"]; provenance (SPIFFE ID, KID, attestation)
 - Optional: classification (C2 default); decision_basis; legal_hold
- **Enforcement Note:** Orchestrators and CI/CD PEPs MUST verify provenance and dual approvals for production, and MUST enforce attested evidence presence and validity (observed_hash + evidence_attestation) for any pass determination.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative above).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url available to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each Schema Capsule, defines testable requirements.

B3. Config Monitor Agent

Agent Blueprint [Informative]

Purpose: Detect configuration drift in near–real time and either (a) auto-remediate via configuration management or (b) open a PR/ticket for governed remediation.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **OpenTelemetry (OTel) config events:** file/registry/K8s resource drift emitted as logs/metrics/traces (key, previous, current, baseline_ref, severity).
- **CMDB / Inventory deltas (REST/GraphQL):** attribute changes to CIs and relationships (who changed, when, ticket linkage).

Model training / knowledge (what the LLM relies on):

- **Drift ontology & rulepack:** mapping of `baseline_ref` to expected state; platform-specific remediation playbooks (Ansible/Puppet/Chef) and Git PR templates.
- **RAG sources:** baseline repo, golden host configs, approved remediation snippets, CAB windows, service owner map; never train on regulated logs—use `evidence_refs`.
- **Guardrails:** enforce **constraints** such as `rollback_ttl_minutes`, `change_window`, `region`, `auto_remediate=false|true`; write scopes only to PR endpoints and config orchestrators.

Decisions it makes (deterministic + model-assisted):

- **Drift detection & correlation:** confirm OTel drift against CMDB delta (if any) and `baseline_ref`; de-dupe repeated signals.
- **Remediation path selection:** choose **ConfigSet** (automated) vs **PR** (governed) vs **suggestion only** based on env, risk, window, and constraints.
- **Risk & blast radius:** compute **change_risk** and require HITL when thresholds exceeded or when `env=prod`.
- **Rollback planning:** create a time-boxed rollback (per `rollback_ttl_minutes`) for automated changes.

Routing / where outputs go:

- **DriftAlert** → Kafka/AMQP for SOC/IR and platform teams.
- **RemediationSuggested** → stream + ticket if auto-remediate is disabled or outside change window.
- **ConfigSet** → Ansible/Puppet/Chef API (staging or non-prod; prod after approvals).
- **PRs** → baseline repos (Git) for governed remediation.

Automation scope vs. manual/HITL:

- **Fully automated:** drift validation, correlation, suggestion generation, non-prod ConfigSet dispatch with rollback, PR creation.
- **HITL required:** any prod enforcement; **change_risk ≥ 0.7** ; K8s changes with eviction potential; Windows domain-wide GPO deltas.
- **Manual outside agent:** CAB scheduling exceptions; emergency change freezes; contentious remediation disputes.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **OpenTelemetry (OTel) config events** — file/registry/K8s drift as logs/metrics/traces
2. **CMDB / Inventory deltas (REST/GraphQL)** — CI attribute changes

Example: Consumed Protocol 1 — OpenTelemetry (OTel) config events

[Informative]

Native payload

```
{
  "timestamp": "2025-08-15T11:58:21Z",
  "resource": {
    "service.name": "config-watcher",
    "host.name": "srv-001",
    "environment": "production",
    "region": "us-east-1"
  },
  "attributes": {
    "event_type": "config_drift",
    "source": "file:/etc/ssh/sshd_config",
    "key": "PermitRootLogin",
    "previous": "no",
    "current": "yes",
    "detection_method": "file_hash_diff",
    "baseline_ref": "CIS-Linux-L1-1.0.0#5.2.8",
    "severity": "high"
  }
}
```

MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b3-otel-1111-2222-3333-4444",
    "thread_id": "uuid-srv-001-ssh-2025-08-15",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
    "role": "ConfigMonitorAgent",
    "intent": "monitor",
    "policy_refs": ["CIS-Linux-L1-1.0.0#5.2.8", "800-53 CM-6"],
    "constraints": ["rollback_ttl_minutes:120", "change_window:offhours", "region:us-east-1", "auto_remediate:false"],
    "decision_basis": {
      "evidence_refs": ["uri://otel/logs/config-watcher/srv-001/2025-08-15T11:58:21Z"],
      "confidence": 0.98,
      "explanation_ref": "uri://kb/drift/ssh-permitrootlogin"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/config-monitor-agent",
      "signing_kid": "kid-otlp-b3-01",
      "attestation_ref": "uri://slsa/attestations/config-monitor@sha256:otlp01"
    },
    "classification": "C2",
    "legal_hold": false
  },
  "native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 2 — CMDB / Inventory deltas [Informative]

Native payload

```
{
  "ci_id": "CISrv001",
  "ci_name": "srv-001",
  "env": "production",
  "region": "us-east-1",
  "attribute": "ssh.permit_root_login",
  "old_value": "no",
  "new_value": "yes",
  "changed_by": "deploy.bot",
  "change_ts": "2025-08-15T11:57:40Z",
  "related_change_ticket": "CHG0054321"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b3-cmdb-5555-6666-7777-8888",
    "thread_id": "uuid-cmdb-delta-CISrv001-ssh",
    "task_id": "uuid-eeee-ffff-1111-2222",
    "role": "ConfigMonitorAgent",
    "intent": "monitor",
    "policy_refs": ["CIS-Linux-L1-1.0.0#5.2.8", "CAB-SCHED"],
    "constraints": ["rollback_ttl_minutes:120", "change_window:offhours", "region:us-east-1"],
    "decision_basis": {
```

```

    "evidence_refs": [
      "uri://servicenow/cmdb/ci/CISrv001/changes/2025-08-15T11:57:40Z",
      "uri://servicenow/change/CHG0054321"
    ],
    "confidence": 0.95,
    "explanation_ref": "uri://kb/drift/cfg-vs-cmdb-delta-correlation"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/config-monitor-agent",
    "signing_kid": "kid-cmdb-b3-02",
    "attestation_ref": "uri://slsa/attestations/config-monitor@sha256:cmdb02"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **ConfigSet** to Ansible/Puppet/Chef (gRPC/HTTPS)
- **PRs** to baseline repos (Git webhooks/REST)
- **DriftAlert / RemediationSuggested** (Kafka/AMQP)

MCP context (required) [Informative]

mission_id; role="ConfigMonitorAgent"; intent="monitor"; policy_refs; provenance (SPIFFE ID, signing key, attestation); decision_basis (evidence_refs, confidence, explanation_ref)

MCP context (optional) [Informative]

constraints (rollback_ttl_minutes, change_window, region, auto_remediate);
classification (C1–C3); legal_hold

Enforcement note [Informative]

PEPs in config orchestrators and CI/CD MUST verify provenance.attestation; MUST enforce constraints (e.g., deny prod enforcement without approvals; respect change_window and region residency; honor rollback_ttl).

NIST SP 800-160v2 linkage [Informative]

Develop/Implement/Evaluate — maintain secure state; promptly detect and control drift for resilient operations.

Automation feasibility [Informative]

High: detection is fully automatable; production remediation is policy/HITL gated.

Output Contracts (merged) [Informative]

OC-1: DriftAlert (Event) [Informative]

- **Producer(s):** B3
- **Topic/Path:** kafka://sec.config.drift.v1 (or AMQP)
- **Schema/Format:** DriftAlert@1.0 with fields: alert_id, asset_uid, source, key, previous, current, baseline_ref, severity, env, region, policy_refs[], evidence_refs[], classification_label, provenance
- **Classification:** C2
- **Delivery:** at-least-once (consumers dedupe on alert_id)
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(asset_uid, key, current_hash, timestamp_floor_60s)
- **Ack/Nack:** broker ACK; NACK → dead-letter
- **Timeouts/Retry:** broker-configured; producer retry<=5x
- **Side-Effects:** optional ticket when severity >= high and auto_remediate=false
- **HITL Token:** none
- **Observability:** trace_id, mission_id, classification_label, provenance.attestation
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=DriftAlert@1.0 | json_schema_uri=uri://schema/drift-alert-1.0.json | sha256=
| producers=B3 | consumers={IR-01,Platform-01,B2} | accepts=1.0–1.x

Conformance: This capsule and the corresponding MCP schema define testable requirements.

OC-2: RemediationSuggested (Event) [Informative]

- **Producer(s):** B3
- **Topic/Path:** kafka://sec.config.remediation_suggested.v1
- **Schema/Format:** RemediationSuggested@1.0 with fields: suggestion_id, asset_uid, delta_summary, playbook_ref|pr_template_ref, rollback_ttl_minutes, change_window, approvals_required, change_risk, blast_radius_score, evidence_refs[], policy_refs[]
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per-asset_uid
- **Idempotency-Key:** sha256(asset_uid, key, delta_hash)
- **Ack/Nack:** broker ACK; NACK → dead-letter
- **Timeouts/Retry:** broker-configured; retry<=5x
- **Side-Effects:** open ticket if auto_remediate=false or outside change_window
- **HITL Token:** optional (requested when approvals_required>0)
- **Observability:** trace_id, mission_id, change_risk, provenance
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When auto_remediate=false OR outside allowed change_window

schema_id=RemediationSuggested@1.0 | json_schema_uri=uri://schema/remediation-suggested-1.0.json | sha256= | producers=B3 | consumers={ITSM-01,Platform-01}

Conformance: Normative when condition is met.

OC-3: ConfigSetDispatch (Orchestrator) [Informative]

- **Producer(s):** B3
- **Topic/Path:** POST /orchestrator/configset (Ansible/Puppet/Chef)
- **Schema/Format:** ConfigSet@1.0 with fields: plan_id, target_scope, env, deltas[], rollback_cmd|playbook_ref, rollback_ttl_minutes, approvals, evidence_refs[], policy_refs[]
- **Classification:** C2 (C3 if secrets/paths exposed)
- **Delivery:** exactly-once per plan_id (receiver enforces idempotency)
- **Ordering:** per-target_scope
- **Idempotency-Key:** sha256(plan_id)
- **Ack/Nack:** 201 Created or job_id; NACK on policy/validation failure
- **Timeouts/Retry:** ack<=60s; retry<=5 with exp backoff; on failure emit RemediationSuggested and open ticket
- **HITL Token:** required for env=prod or change_risk >= 0.7
- **Observability:** trace_id, mission_id, job_id, rollback_ttl_minutes, provenance.attestation
- **Retention/TTL:** >= 7 years (audit evidence)

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When auto_remediate=true AND inside allowed change_window AND env permits automation

schema_id=ConfigSet@1.0 | json_schema_uri=uri://schema/configset-1.0.json | sha256= | producers=B3 | consumers={Ansible-01,Puppet-01,Chef-01}

Conformance: Normative when condition is met.

OC-4: BaselinePR (Governed Remediation) [Informative]

- **Producer(s):** B3
- **Topic/Path:** Git PR to sec/baselines or infra/config
- **Schema/Format:** BaselinePR@1.0 with fields: pr_id, repo, branch, files_changed[], delta_summary, change_risk, blast_radius_score, required_reviewers[], rollback_plan_ref, evidence_refs[], policy_refs[]
- **Classification:** C2

- **Delivery:** exactly-once per pr_id
- **Ordering:** per-repo/branch
- **Idempotency-Key:** sha256(repo, branch, pr_head_sha)
- **Ack/Nack:** PR number; NACK on validation or checks failing
- **Timeouts/Retry:** ack<=60s; retry<=5; on repeated failure emit RemediationSuggested
- **HITL Token:** required (PR implies human approval)
- **Observability:** trace_id, mission_id, pr_url, provenance
- **Retention/TTL:** repo retention; audit trail >= 7 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When remediation path is “PR” (env=prod or governance dictates PR over direct config)

schema_id=BaselinePR@1.0 | json_schema_uri=uri://schema/baseline-pr-1.0.json | sha256= | producers=B3 | consumers={Git-01,Reviewer-Portal}

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, correlating, deciding, dispatching, awaiting_approval, verifying, rolled_back, failed, closed }

transition(idle -> ingesting) when OTel drift OR CMDB delta arrives

transition(ingesting -> correlating) when evidence sets collected

transition(correlating -> deciding) when baseline_ref and owner resolved

transition(deciding -> dispatching) when remediation path selected

transition(dispatching -> awaiting_approval) when env=prod OR change_risk >= 0.7

transition(dispatching -> verifying) when automated job_id returned

transition(verifying -> closed) when state converges to baseline

transition(verifying -> rolled_back) when rollback_ttl_minutes expires without convergence

transition(* -> failed) on validation error or policy constraint violation

idempotency_key(DriftAlert) = sha256(asset_uid, key, current_hash,
timestamp_floor_60s)

idempotency_key(ConfigSet) = sha256(plan_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 DriftAlert	Required	Always	Immediate visibility of drift
OC-2 RemediationSuggested	Conditionally Required	auto_remediate=false OR outside change_window	Governed remediation workflow
OC-3 ConfigSetDispatch	Conditionally Required	auto_remediate=true AND within change_window AND env permits automation	Fast convergence to baseline
OC-4 BaselinePR	Conditionally Required	PR path chosen (e.g., env=prod or governance requires PR)	Audited, review-gated convergence

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** CM-6, AU-12, CIS items referenced by baseline_ref; internal change policy.
- **HITL required:** env=prod; change_risk >= 0.7; blast_radius_score >= theta_high; K8s changes with eviction risk; domain-wide Windows GPO changes.

- **Manual outside agent:** CAB exceptions; moratorium adherence.

SLOs and KPIs [Informative]

- **DriftDetect_MTTD** <= 5 min
- **DriftConverge_p95 (non-prod)** <= 60 min
- **RollbackSuccessRate_30d** >= 99.5 percent
- **FalsePositiveDrift_30d** <= 1 percent
- **AutoRemediation_Success_p95** >= 98 percent

Outputs index [Informative]

[OC-1 DriftAlert], [OC-2 RemediationSuggested], [OC-3 ConfigSetDispatch], [OC-4 BaselinePR]

Technical Implementation Details (B3) [Informative]

Model and training profile [Informative]

model_id=config-monitor-model; temperature=0.0; max_tokens_out=300
 prompt_pack_id=drift-correlation-v1 (baseline mapping + remediation templates)
 RAG: sources={baseline repo, playbook library, CAB calendar, owner map};
 max_docs=10; min_similarity=0.80; citations required
 fine_tuning/adapters: none initially; evaluate on correlation precision/recall and delta minimality
 guardrails: enforce constraints; prod writes only via approved PRs or signed HITL tokens

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency
 episodic_memory: per mission_id drift ledger; ttl=365d
 semantic_memory: namespaces=["baselines","playbooks","owners","cab"];
 embeddings=text-embedding-sec-v1; k=10
 durable_state_store: event-sourced journal of alerts, jobs, PRs; snapshot hourly
 consistency: at-least-once (events); exactly-once (ConfigSet per plan_id)
 idempotency: per Output Contracts

Decision and routing logic [Informative]

$\text{drift_score} = 0.5 \cdot \text{severity_weight} + 0.2 \cdot \text{exposure_flag} + 0.2 \cdot \text{service_criticality} + 0.1 \cdot \text{repeat_count}$

$\text{change_risk} = 0.4 * \text{blast_radius} + 0.3 * \text{service_impact} + 0.2 * (1 - \text{evidence_confidence}) + 0.1 * \text{churn_rate}$

path = if auto_remediate=true and within(change_window) and env!="prod" and change_risk < 0.7

then "ConfigSet"

else if governance_requires_pr or env=="prod"

then "PR"

else "Suggest"

Model Risk Management [Informative]

continuous_validation: daily replays with labeled drift cases; adversarial tests for noisy/duplicate signals

thresholds: correlation_precision_7d >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly edge-case drifts (K8s/Windows)

rollback_policy: revert playbook versions if failure rate > 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: what drift, why chosen path, delta summary, risk scores, rollback plan, evidence_refs, policy_refs

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; stable fields; retention per classification and legal_hold

Incident Response Integration [Informative]

emit DriftAlert to SIEM; tag linked incidents when drift coincides with suspicious activity; attach evidence_refs

Stakeholder Feedback Loop [Informative]

collect reviewer labels on suggestions/PRs; feed rubric/playbook updates after governance review (no auto-training on regulated evidence)

Data Sovereignty and Legal Hold [Informative]

respect region constraints for orchestration and storage; legal_hold=true → retain related logs and artifacts indefinitely

Interfaces (links only) [Informative]

Consumes: OTel config events; CMDB deltas

Produces: OC-1 DriftAlert; OC-2 RemediationSuggested; OC-3 ConfigSetDispatch; OC-4 BaselinePR

Safety and abuse prevention [Informative]

kill_switch on provenance or signature anomalies; cap concurrent changes; sandbox mode outside change_window

Testing and validation [Informative]

contract tests for all OCs; replay suites; negative tests for forbidden windows/regions; rollback drills

Deployment and lifecycle [Informative]

scale by asset shard; canary playbooks; SBOM and attestations; sign all outputs

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, AU-12); NIST SP 800-137; NIST CSF 2.0 (PR.IP, DE.CM); CIS Benchmarks; ISO/IEC 27002:2022

MCP-Native Protocol Specification (B3) [Normative]

- **Native Protocol(s) Consumed:** OTel config events; CMDB/Inventory deltas
- **Native Protocol(s) Produced:** ConfigSet (orchestrator); Baseline PRs; DriftAlert/RemediationSuggested events
- **MCP Context Fields:**
 - **Required:** mission_id; role="ConfigMonitorAgent"; intent="monitor"; policy_refs; provenance (SPIFFE ID, signing KID, attestation); decision_basis (evidence_refs, confidence, explanation_ref)
 - **Optional:** constraints (rollback_ttl_minutes, change_window, region, auto_remediate); classification; legal_hold
- **Enforcement Note:** PEPs MUST verify provenance.attestation and enforce constraints & approvals before execution.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative above).

- **Transparency hooks:** `classification_label`, `provenance.attestation`, `decision_rationale_url` exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

B4. Change Governance Agent

Agent Blueprint [Informative]

Purpose: Automate CAB checks for security-affecting changes: validate risk, ensure approved windows, enforce canary/rollback, and issue formal approvals to orchestration systems.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **ChangeIntent events (Kafka/AMQP):** proposed change scope, risk, targets, proposed window, rollback capability, related incidents and references.
- **Calendar APIs (CalDAV/REST):** maintenance windows, blackout/freezes, environment allowlists, policy notes.

Model training / knowledge (what the LLM relies on):

- **Governance policy/rulepack:** SoD, CAB policy levels (HITL-A/B/C), canary/rollback mandates, PR gating rules.
- **Mapping library:** linkage to NIST 800-53 CM-6, AU-12; internal CAB standards (e.g., CAB-STD-01), environment taxonomy, service criticality map.
- **RAG sources:** change history, failure/rollback rates, prior approvals, platform risk catalogs; do not train on regulated tickets—use `evidence_refs`.
- **Guardrails:** read-only on calendars; write scopes limited to approval tokens, status checks, and orchestrator APIs; enforce declared **constraints** (e.g., `change_window:offhours`, `canary_required`).

Decisions it makes (deterministic + model-assisted):

- **Eligibility & windowing:** verify requested window against calendars, freeze periods, and `allowed_envs`.
- **Risk & SoD gates:** compute **change_risk** and required HITL level; verify separation of duties on requester vs approver.

- **Plan synthesis:** require **DeployPlan** and **RollbackPlan** structure for approved changes; ensure canary if mandated.
- **Final decision:** approve | approve_with_conditions | deny | reschedule, with rationale and evidence.

Routing / where outputs go:

- **ChangeGovernanceDecision** → Kafka/AMQP for broad visibility and downstream automation.
- **ChangeApproval / DeployPlan / RollbackPlan** → SOAR/orchestrators via REST/gRPC (tokenized, signed).
- **Git Status Checks** → pass/fail on PRs that gate CI/CD merges.
- **CABAuditRecord** → event stream (and/or evidence store) for audit trail.

Automation scope vs. manual/HITL:

- **Fully automated:** policy checks, calendar validation, SoD verification, canary/rollback requirement checks, status check postings.
- **HITL required:** per constraint level (HITL-A/B/C), env=prod, change_risk >= 0.7, CrownJewels impact, missing rollback, large blast radius.
- **Manual outside agent:** emergency waivers, dispute arbitration, change/classification policy updates.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **Kafka / AMQP — ChangeIntent** — proposed change metadata from RCA/Baseline/Remediation planners
2. **Calendar APIs (CalDAV / REST)** — maintenance windows and freeze periods

Example: Consumed Protocol 1 — Kafka/AMQP (ChangeIntent) [Informative]

Native payload

```
{
  "change_intent_id": "CI-2025-0815-0034",
  "source": "BaselineComplianceAgent",
  "risk_level": "High",
```

```

"summary": "Enable syscall auditing for execve across prod Linux",
"targets": [{"asset_group": "linux-prod", "count": 214}],
"requires_canary": true,
"proposed_window": "2025-08-16T01:00:00Z/2025-08-16T03:00:00Z",
"rollback_supported": true,
"related_incident": "INC-45877",
"references": [
  "uri://kb/baselines/cis-linux-l1#5.2.15",
  "uri://dfir/rca/RCA-2025-0815-0021"
]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b4-cab-1111-2222-3333-4444",
    "thread_id": "uuid-ci-CI-2025-0815-0034",
    "task_id": "uuid-aaaa-bbbb-cccc-dddd",
    "role": "ChangeGovernanceAgent",
    "intent": "govern",
    "policy_refs": ["CAB-STD-01", "CM-6", "AU-12"],
    "constraints": ["HITL-B", "change_window:offhours", "canary_required"],
    "decision_basis": {
      "evidence_refs": [
        "uri://kafka/change-intents/CI-2025-0815-0034",
        "uri://dfir/rca/RCA-2025-0815-0021",
        "uri://kb/baselines/cis-linux-l1#5.2.15"
      ]
    }
  }
}

```



```

    ],
    "confidence": 0.93,
    "explanation_ref": "uri://kb/cab/policies/high-risk-with-canary"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/change-governance-agent",
    "signing_kid": "kid-kfk-b4-01",
    "attestation_ref": "uri://slsa/attestations/change-governance@sha256:kfk01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 2 — Calendar APIs (CalDAV/REST) [Informative]
Native payload

```

{
  "window_id": "MW-2025-08-16-01",
  "start": "2025-08-16T01:00:00Z",
  "end": "2025-08-16T03:00:00Z",
  "allowed_envs": ["staging", "production"],
  "freeze_periods": [{"start": "2025-08-31T00:00:00Z", "end": "2025-09-05T23:59:59Z"}],
  "notes": "Quarter-end freeze applies to finance stack"
}

```

MCP-wrapped payload

```

{
  "mcp_context": {

```

```

"mcp_version": "0.9",
"mission_id": "uuid-b4-cal-5555-6666-7777-8888",
"thread_id": "uuid-window-MW-2025-08-16-01",
"task_id": "uuid-eeee-ffff-1111-2222",
"role": "ChangeGovernanceAgent",
"intent": "govern",
"policy_refs": ["CAB-SCHED", "CP-2"],
"constraints": ["change_window:offhours"],
"decision_basis": {
  "evidence_refs": ["uri://cal/mw/MW-2025-08-16-01"],
  "confidence": 0.99,
  "explanation_ref": "uri://kb/cab/window-freeze-rules"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/change-governance-agent",
  "signing_kid": "kid-cal-b4-02",
  "attestation_ref": "uri://slsa/attestations/change-governance@sha256:cal02"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **REST/gRPC:** ChangeApproval (tokenized approval), DeployPlan, RollbackPlan to SOAR/orchestrators.
- **Git Status Checks:** pass/fail gates posted to PRs.

- **Kafka/AMQP:** ChangeGovernanceDecision, CABAuditRecord.

MCP context (required) [Informative]

mission_id; role="ChangeGovernanceAgent"; intent="govern"; policy_refs; constraints (e.g., HITL-A/B/C, change_window, canary_required); provenance (SPIFFE ID, signing key, attestation)

MCP context (optional) [Informative]

classification (C1–C2 typical); decision_basis (evidence_refs, confidence, explanation_ref); legal_hold

Enforcement note [Informative]

PEPs in orchestrators/CI must verify **provenance.attestation**, enforce **constraints** (HITL level, canary_required, change_window), and reject actions lacking valid **ChangeApproval** tokens.

NIST SP 800-160v2 linkage [Informative]

Develop/Implement/Maintain — governed change with rollback assurance and explicit human-in-the-loop thresholds.

Automation feasibility [Informative]

Partial–High: policy/SoD/windowing automated; high-risk paths require human co-sign as dictated by constraint level.

Output Contracts (merged) [Informative]

OC-1: ChangeGovernanceDecision (Event) [Informative]

- **Producer(s):** B4
- **Topic/Path:** kafka://sec.change.decision.v1
- **Schema/Format:** ChangeGovernanceDecision@1.0 with fields: decision_id, change_intent_id, decision{approve|approve_with_conditions|deny|reschedule}, conditions[], required_HITL, window, canary_required, rationale_url, evidence_refs[], policy_refs[], classification_label, provenance
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per change_intent_id

- **Idempotency-Key:** sha256(change_intent_id, decision_hash)
- **Ack/Nack:** broker ACK; NACK → dead-letter
- **Timeouts/Retry:** broker-configured; producer retry<=5x
- **Side-Effects:** triggers status checks and (if approved) issuance of ChangeApproval token
- **HITL Token:** optional (when required_HITL != none)
- **Observability:** trace_id, mission_id, classification_label, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=ChangeGovernanceDecision@1.0 | json_schema_uri=uri://schema/change-governance-decision-1.0.json | sha256= | producers=B4 | consumers={SOAR-01,Orch-01,PRGate-01} | accepts=1.0–1.x

Conformance: Normative.

OC-2: ChangeApproval (Approval Token) [Informative]

- **Producer(s):** B4
- **Topic/Path:** POST /orchestrator/approvals or gRPC Approve(ChangeIntent)
- **Schema/Format:** ChangeApproval@1.0 with fields: approval_id, change_intent_id, valid_from, valid_until, scope{targets, env}, conditions{canary, rollback_required, HITL_level}, approval_sig(JWS), policy_refs[], provenance
- **Classification:** C2
- **Delivery:** exactly-once per approval_id (consumer enforces idempotency)
- **Ordering:** per change_intent_id
- **Idempotency-Key:** sha256(approval_id)
- **Ack/Nack:** 201 Created; NACK on validation/policy failure
- **Timeouts/Retry:** ack<=30s; retry<=5; open CABAAuditRecord on repeated NACK
- **Side-Effects:** unlocks orchestrator execution for the approved window/scope
- **HITL Token:** required when HITL level is B/C (attach co-sign references)

- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When decision $\in$ {approve, approve_with_conditions} and orchestrator execution is intended

schema_id=ChangeApproval@1.0 | json_schema_uri=uri://schema/change-approval-1.0.json | sha256= | producers=B4 | consumers={SOAR-01,Orch-01}

Conformance: Normative when condition is met.

OC-3: DeployPlan (Execution Plan) [Informative]

- **Producer(s):** B4 (or sourced/validated from upstream agent, but republished under governance)
- **Topic/Path:** POST /orchestrator/deployplan
- **Schema/Format:** DeployPlan@1.0 with fields: plan_id, change_intent_id, canary{size, success_criteria, duration}, steps[], health_checks[], halt_conditions[], evidence_refs[], policy_refs[], provenance
- **Classification:** C2
- **Delivery:** exactly-once per plan_id
- **Ordering:** per change_intent_id
- **Idempotency-Key:** sha256(plan_id)
- **Ack/Nack:** 201 Created; NACK on validation
- **Timeouts/Retry:** ack<=30s; retry<=5; fallback to PR gate fail if repeated NACK
- **Side-Effects:** schedules canary; binds to ChangeApproval validity window
- **HITL Token:** optional (if canary size > threshold in prod)
- **Observability:** trace_id, mission_id, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When canary_required=true OR orchestrator insists on explicit plan

schema_id=DeployPlan@1.0 | json_schema_uri=uri://schema/deploy-plan-1.0.json |

sha256= | producers=B4 | consumers={Orch-01}
Conformance: Normative when condition is met.

OC-4: RollbackPlan (Recovery Plan) [Informative]

- **Producer(s):** B4
- **Topic/Path:** POST /orchestrator/rollbackplan
- **Schema/Format:** RollbackPlan@1.0 with fields: rollback_id, change_intent_id, triggers{SLO breach, error codes, manual}, steps[], restore_points[], time_budget, evidence_refs[], policy_refs[], provenance
- **Classification:** C2
- **Delivery:** exactly-once per rollback_id
- **Ordering:** per change_intent_id
- **Idempotency-Key:** sha256(rollback_id)
- **Ack/Nack:** 201 Created; NACK on validation
- **Timeouts/Retry:** ack<=30s; retry<=5; block approval if absent for high-risk
- **Side-Effects:** registers rollback hooks with orchestrator
- **HITL Token:** optional
- **Observability:** trace_id, mission_id
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When risk_level ∈ {Medium, High} OR policy mandates rollback coverage
schema_id=RollbackPlan@1.0 | json_schema_uri=uri://schema/rollback-plan-1.0.json |
sha256= | producers=B4 | consumers={Orch-01}

Conformance: Normative when condition is met.

OC-5: PRStatusCheck (Git Gate) [Informative]

- **Producer(s):** B4
- **Topic/Path:** Git Status API (POST /repos/:org/:repo/statuses/:sha)

- **Schema/Format:** PRStatusCheck@1.0 with fields: pr_id|sha, context="change-governance", state{success|failure|pending}, description, target_url(rationale), evidence_refs[], policy_refs[], provenance
- **Classification:** C1–C2
- **Delivery:** at-least-once
- **Ordering:** per sha
- **Idempotency-Key:** sha256(sha, state, context)
- **Ack/Nack:** 201 Created; retry on 5xx
- **Side-Effects:** blocks/permits PR merge
- **HITL Token:** none
- **Observability:** trace_id, mission_id
- **Retention/TTL:** per repo retention

Schema Capsule (OC-5) [Normative]

Requirement Level: Conditionally Required

Condition: When PR gating is used for change enforcement

schema_id=PRStatusCheck@1.0 | json_schema_uri=uri://schema/pr-status-check-1.0.json | sha256= | producers=B4 | consumers={Git-01,CI-01}

Conformance: Normative when condition is met.

OC-6: CABAuditRecord (Audit Event) [Informative]

- **Producer(s):** B4
- **Topic/Path:** kafka://sec.change.audit.v1
- **Schema/Format:** CABAuditRecord@1.0 with fields: record_id, change_intent_id, actions[], approvers[], timestamps, decision, conditions, tokens{approval_id}, evidence_refs[], policy_refs[], classification_label, provenance
- **Classification:** C2
- **Delivery:** at-least-once
- **Ordering:** per change_intent_id
- **Idempotency-Key:** sha256(change_intent_id, decision_hash, last_action_ts_floor_60s)

- **Ack/Nack:** broker ACK; NACK → dead-letter
- **Timeouts/Retry:** broker-configured
- **Side-Effects:** immutable audit append; drives compliance reporting
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance.attestation
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-6) [Normative]

Requirement Level: Required

Condition: Always (auditability is mandatory)

schema_id=CABAuditRecord@1.0 | json_schema_uri=uri://schema/cab-audit-record-1.0.json | sha256= | producers=B4 | consumers={Audit-01,GRC-01}

Conformance: Normative.

State machine (concise) [Informative]

states = { idle, ingesting, validating_policy, checking_window, determining_hitl, planning, issuing_tokens, gating_prs, awaiting_cosign, approved, denied, rescheduled, contestation_workflow, failed, closed }

transition(idle -> ingesting) when ChangeIntent arrives

transition(ingesting -> validating_policy) when inputs normalized

transition(validating_policy -> checking_window) when SoD/constraints pass

transition(checking_window -> determining_hitl) when window eligible

transition(determining_hitl -> planning) when HITL level determined and canary/rollback required

transition(planning -> issuing_tokens) when DeployPlan/RollbackPlan validated

transition(issuing_tokens -> gating_prs) when ChangeApproval issued

transition(gating_prs -> approved) when PR status is success OR non-PR path green

transition(* -> awaiting_cosign) when external co-sign required (e.g., A1 policy_cosign)

transition(* -> contestation_workflow) when dispute opened or approver challenges rationale

transition(* -> denied) on policy violation or missing rollback for high risk

transition(* -> rescheduled) when window conflicts / freeze detected

transition(* -> failed) on timeouts or attestation errors

idempotency_key(Decision) = sha256(change_intent_id, decision_hash)

idempotency_key(Approval) = sha256(approval_id)

idempotency_key(DeployPlan) = sha256(plan_id)

idempotency_key(RollbackPlan) = sha256(rollback_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 ChangeGovernanceDecision	Required	Always	Authoritative decision & conditions
OC-2 ChangeApproval	Conditionally Required	Decision approves and orchestrator execution intended	Enables controlled execution
OC-3 DeployPlan	Conditionally Required	Canary required or orchestrator mandates explicit plan	Safe, staged rollout
OC-4 RollbackPlan	Conditionally Required	Medium/High risk or policy requires rollback	Rapid recovery path
OC-5 PRStatusCheck	Conditionally Required	PR gating used for enforcement	Prevents unsafe merges
OC-6 CABAuditRecord	Required	Always	Compliance evidence and traceability

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
 - **Conditionally Required:** Must be implemented when trigger condition is met
 - **Optional:** May be implemented for enhanced functionality
-

Policies and HITL gates [Informative]

- **policy_refs:** CAB-STD-01, CM-6, AU-12, internal SoD and scheduling standards.
- **HITL required:** env=prod; change_risk >= 0.7; CrownJewels impact; missing tested rollback; canary omitted when mandated.
- **Automatic escalation triggers:** model_confidence < theta_low; window conflict; SoD violation; stakeholder_disagreement_score >= 0.5.
- **Manual outside agent:** emergency waivers; dispute arbitration; moratorium overrides.

SLOs and KPIs [Informative]

- DecisionPublishAck_p95 <= 30 s
- ApprovalIssue_p95 <= 60 s (post-HITL)
- PostChangeRollbackRate_30d <= 2 percent
- SoDViolationCatchRate_7d >= 99.9 percent
- AuditCompleteness_100 (no missing CABAuditRecords)

Outputs index [Informative]

[OC-1 ChangeGovernanceDecision], [OC-2 ChangeApproval], [OC-3 DeployPlan], [OC-4 RollbackPlan], [OC-5 PRStatusCheck], [OC-6 CABAuditRecord]

Technical Implementation Details (B4) [Informative]

Model and training profile [Informative]

model_id=change-governance-model; temperature=0.0; max_tokens_out=400
prompt_pack_id=cab-governance-v1 (SoD, windowing, canary/rollback rules)
RAG: sources={CAB policy repo, change history, calendar feeds, risk catalogs};
max_docs=12; min_similarity=0.80; citations required

fine_tuning/adapters: none initially; eval on decision accuracy vs gold CAB outcomes
guardrails: write scopes only to approval/status APIs; deny if attestation missing or constraints unmet

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency_then_importance
episodic_memory: per mission_id ledger of intents, decisions, approvals; ttl=7y
semantic_memory: namespaces=["cab-policies","calendars","risk-catalog","history"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: event-sourced journal; daily snapshots
consistency: at-least-once (events); exactly-once (tokens per approval_id)
idempotency: as per Output Contracts

Decision and routing logic [Informative]

change_risk = 0.35*blast_radius + 0.25*service_criticality
 + 0.20*(1 - rollback_confidence)
 + 0.10*historical_failure_rate
 + 0.10*operational_churn

required_hitl =

if env=="prod" or change_risk >= 0.7 then "B"
else if canary_required and canary_size > threshold then "A"
else "none"

approve_if = window_valid and SoD_ok and rollback_present (if risk >= medium)
 and (canary_present if canary_required)

routing: on approve → issue ChangeApproval (+DeployPlan/RollbackPlan) → set
PRStatusCheck=success; on deny → PRStatusCheck=failure; always emit
CABAuditRecord.

Model Risk Management [Informative]

continuous_validation: daily replay of historical change sets; adversarial tests for
SoD/window edge cases
thresholds: decision_accuracy_7d >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly CAB bypass scenarios (forged windows, missing rollback)
rollback_policy: revert rulepack if false-approve rate increases by ≥ 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: who/what/when/why, SoD results, window/ freeze evaluation, risk scores, canary/rollback validation, evidence_refs
UI/API: expose classification_label, provenance.attestation, decision_rationale_url
audit_log_format: JSONL, stable field order; retention per legal_hold ($\geq 7y$)

Incident Response Integration [Informative]

if related_incident present, attach decision artifacts to IR case; deny or require tighter conditions during active incidents on CrownJewels.

Stakeholder Feedback Loop [Informative]

collect approver feedback labels on decisions; feed governance rule tuning after review; never auto-train on regulated tickets.

Data Sovereignty and Legal Hold [Informative]

enforce region constraints when posting approvals; legal_hold=true $\rightarrow$ override TTL and freeze decision artifacts.

Interfaces (links only) [Informative]

Consumes: ChangeIntent (Kafka/AMQP); Calendar APIs
Produces: OC-1 Decision; OC-2 Approval; OC-3 DeployPlan; OC-4 RollbackPlan; OC-5 PRStatusCheck; OC-6 CABAuditRecord

Safety and abuse prevention [Informative]

kill_switch on attestation failure; cap approvals/hour; deny outside approved windows; secondary approval for scope expansion mid-flight.

Testing and validation [Informative]

contract tests for all OCs; SoD and window simulators; rollback drills; status check integration tests.

Deployment and lifecycle [Informative]

scale by change domain; canary rulepack updates; SBOM + attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (CM-6, AU-12, CP-2), NIST SP 800-137; NIST CSF 2.0 (PR.IP, DE.CM, RC.IM); ISO/IEC 27002:2022

MCP-Native Protocol Specification (B4) [Normative]

- **Native Protocol(s) Consumed:** Kafka/AMQP ChangeIntent; Calendar APIs (CalDAV/REST)
- **Native Protocol(s) Produced:** REST/gRPC
ChangeApproval/DeployPlan/RollbackPlan; Git PR status checks; Kafka/AMQP ChangeGovernanceDecision, CABAuditRecord
- **MCP Context Fields:**
 - **Required:** mission_id; role="ChangeGovernanceAgent"; intent="govern"; policy_refs; constraints; provenance (SPIFFE ID, KID, attestation)
 - **Optional:** classification; decision_basis; legal_hold
- **Enforcement Note:** Downstream PEPs MUST verify provenance, approval token validity (time/scope/conditions), and enforce constraints (HITL level, canary_required, change_window).
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative above).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

B5. Patch Orchestration Agent

Agent Blueprint [Informative]

Purpose: Prioritize, schedule, and verify patches across OS, container, application, and device fleets. Consolidates CVEs/KBs/vendor advisories with local vuln intel and asset criticality; creates patch jobs (WSUS/MDM/Yum/Apt/etc.) and tracks **PatchOutcome**.

Operational Narrative [Informative]

Inputs used (authoritative sources):

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **CVE feeds (NVD/CISA KEV JSON):** id, severity/score, vectors, affected CPEs, references.
- **KB feeds (MSRC/Windows Update):** KB id, released date, severity, reboot_required, supersedence.
- **Vendor advisories (OVAL/XML or JSON):** OS/app affected, minimal fixed versions, mapping tests.
- **Vulnerability platform REST:** host findings (CVE↔asset), first/last seen, remediation text.
- **CMDB / Asset Graph:** ownership, business service, criticality (e.g., CrownJewel), env, region, SLA tiers.

Model training / knowledge (what the LLM relies on):

- **Prioritization rulepack:** exploitability/KEV boost, business criticality weighting, exposure (internet/DMZ), maintenance tier SLAs, reboot and kernel/db risk tables.
- **RAG sources:** CVE/OVAL/KB corpora, local vuln findings history, patch success/rollback stats, CAB calendars, owner directory. Do not train on regulated scans—use evidence_refs.
- **Guardrails:** write scopes restricted to orchestrators and status topics; require ChangeApproval token for prod; enforce constraints (sla_days, canary_required, change_window, region, hitl flags).

Decisions it makes (deterministic + model-assisted):

- **Patch priority & scope selection:** which assets/packages first, canary set size, sequencing (waves).
- **Channel selection:** WSUS/Intune/MDM vs package managers vs container rebuilders (Helm/image pipeline).
- **Risk gates & HITL:** require approvals for kernel/DB/CrownJewel patches; coordinate with B4 decisions.
- **Verification plan:** post-patch re-scan, package/version proofs, sanity checks, and rollback hooks.

Routing / where outputs go:

- **PatchJobDispatch** → WSUS/Intune/MDM; Yum/DNF/Apt/Zypper; Chocolatey/Winget; K8s Helm/image rebuilders.

- **PatchWavePlan / RebootSchedule** → orchestrators (as applicable).
- **PatchOutcome** → Kafka/AMQP (with verification evidence) and ticket updates.

Automation scope vs. manual/HITL:

- **Fully automated:** CVE/KB/advisory ingestion; asset correlation; job building; non-prod dispatch; container rebuild triggers; evidence collection.
- **HITL required:** kernel or database patches on CrownJewels; PRs that change image base for regulated workloads; any prod patch without ChangeApproval; reboot windows outside policy.
- **Manual outside agent:** emergency deferrals/waivers; business outage alignment; exception policy changes.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **CVE feeds (JSON)** — NVD/CISA KEV (vuln metadata, scores, affected CPEs)
2. **KB feeds (JSON/RSS)** — MSRC / Windows Update KBs
3. **Vendor advisories (OVAL/XML or JSON)** — RHSA/OVAL, USN, DSA, etc.
4. **Vulnerability platform REST (JSON)** — Tenable/Qualys/Rapid7 findings
5. **CMDB / Asset Graph (REST/GraphQL)** — asset criticality, owner, env, tier

Example: Consumed Protocol 1 — CVE Feeds (NVD/CISA KEV JSON) [Informative]

Native payload

```
{
  "cve": {
    "id": "CVE-2025-12345",
    "sourceIdentifier": "vendor@example.com",
    "published": "2025-08-14T16:05:00Z",
    "descriptions": [{"lang": "en", "value": "Path traversal in Apache HTTP Server..."}]
  },
  "metrics": {
    "cvssV3_1": {
```

```

    "baseScore": 9.8,
    "baseSeverity": "CRITICAL",
    "vectorString": "CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H"
  }
},
"configurations": {
  "nodes": [
    {
      "cpeMatch": [{"vulnerable": true, "criteria":
"cpe:2.3:a:apache:http_server:*:*:*:*:*:*", "versionEndExcluding": "2.4.60"}]}
  ]
},
"references": [{"url": "https://httpd.apache.org/security/vulnerabilities_24.html"}]
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b5-cve-1111-2222-3333-4444",
    "thread_id": "uuid-cve-CVE-2025-12345",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "PatchOrchestrationAgent",
    "intent": "implement",
    "policy_refs": ["SI-2", "RA-5", "CM-6"],
    "constraints": ["sla_days:7", "canary_required:true", "change_window:offhours"],
    "decision_basis": {
      "evidence_refs": [
        "uri://nvd/cve/CVE-2025-12345",

```



```

    "https://httpd.apache.org/security/vulnerabilities_24.html"
  ],
  "confidence": 0.96,
  "explanation_ref": "uri://models/patch-priority/cvss-exploitability-v3_1"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/patch-orchestration-agent",
  "signing_kid": "kid-nvd-b5-01",
  "attestation_ref": "uri://slsa/attestations/patch-orchestration@sha256:nvd01"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 2 — KB Feeds (MSRC / Windows Update)

[Informative]

Native payload

```

{
  "kb_id": "KB5039212",
  "vendor": "Microsoft",
  "released": "2025-08-13T17:00:00Z",
  "severity": "Critical",
  "cve_ids": ["CVE-2025-22301", "CVE-2025-22303"],
  "affected_products": ["Windows Server 2022"],
  "supersedes": ["KB5038123"],
  "reboot_required": true
}

```

```
}
```

MCP-wrapped payload

```
{
```

```
  "mcp_context": {
```

```
    "mcp_version": "0.9",
```

```
    "mission_id": "uuid-b5-kb-2222-3333-4444-5555",
```

```
    "thread_id": "uuid-kb-KB5039212",
```

```
    "task_id": "uuid-ee11-ff22-0011-2233",
```

```
    "role": "PatchOrchestrationAgent",
```

```
    "intent": "implement",
```

```
    "policy_refs": ["SI-2", "CM-6"],
```

```
    "constraints": ["sla_days:7", "hitl_required:kernel_or_reboot",  
"change_window:offhours"],
```

```
    "decision_basis": {
```

```
      "evidence_refs": ["uri://msrc/kb/KB5039212"],
```

```
      "confidence": 0.94,
```

```
      "explanation_ref": "uri://kb/patching/windows-reboot-risk-tiering"
```

```
    },
```

```
    "provenance": {
```

```
      "producer_spiffe": "spiffe://enterprise/security/patch-orchestration-agent",
```

```
      "signing_kid": "kid-msrc-b5-02",
```

```
      "attestation_ref": "uri://slsa/attestations/patch-orchestration@sha256:msrc02"
```

```
    },
```

```
    "classification": "C2",
```

```
    "legal_hold": false
```

```
  },
```

```
  "native_payload": { "...": "..." }
```

```
}
```

Example: Consumed Protocol 3 — Vendor Advisories (OVAL/XML or JSON)

[Informative]

Native payload

```
<oval_definitions>
  <definitions>
    <definition id="oval:com.redhat.rhsa:def:20252501" class="vulnerability">
      <metadata>
        <title>RHSA-2025:2501 OpenSSL security update</title>
        <reference source="CVE" ref_id="CVE-2025-23456"/>
        <severity>Important</severity>
      </metadata>
      <criteria>
        <criterion test_ref="oval:com.redhat.rhsa:tst:openssl_version_lt_1_1_1w"
comment="openssl < 1.1.1w"/>
      </criteria>
    </definition>
  </definitions>
</oval_definitions>
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b5-oval-3333-4444-5555-6666",
    "thread_id": "uuid-rhsa-2025-2501",
    "task_id": "uuid-4411-5522-6633-7744",
    "role": "PatchOrchestrationAgent",
    "intent": "implement",
```

```

"policy_refs": ["SI-2", "RA-5"],
"constraints": ["sla_days:14", "canary_required:true"],
"decision_basis": {
  "evidence_refs": ["uri://redhat/oval/oval:com.redhat.rhsa:def:20252501"],
  "confidence": 0.93,
  "explanation_ref": "uri://kb/oval-to-package-mapping/openssl"
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/patch-orchestration-agent",
  "signing_kid": "kid-oval-b5-03",
  "attestation_ref": "uri://slsa/attestations/patch-orchestration@sha256:oval03"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": "<oval_definitions>...</oval_definitions>"
}

```

Example: Consumed Protocol 4 — Vulnerability Platform REST (asset findings)

[Informative]

Native payload

```

{
  "asset": {"asset_id": "srv-001", "ipv4": "10.2.14.5", "fqdn": "srv-001.corp"},
  "plugin_id": 150412,
  "plugin_name": "Apache HTTPD Path Traversal (CVE-2025-12345)",
  "severity": "Critical",
  "cvss": 9.8,
  "first_seen": "2025-08-14T18:10:00Z",

```

```

"last_seen": "2025-08-15T10:20:00Z",
"solution": "Update httpd to 2.4.60 or later."
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b5-vuln-4444-5555-6666-7777",
    "thread_id": "uuid-srv-001-CVE-2025-12345",
    "task_id": "uuid-cc11-dd22-ee33-ff44",
    "role": "PatchOrchestrationAgent",
    "intent": "implement",
    "policy_refs": ["SI-2", "RA-5", "CM-6"],
    "constraints": ["sla_days:7", "change_window:offhours", "canary_required:true"],
    "decision_basis": {
      "evidence_refs": ["uri://tenable/asset/srv-001/plugin/150412"],
      "confidence": 0.98,
      "explanation_ref": "uri://models/patch-priority/asset-risk-score"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/patch-orchestration-agent",
      "signing_kid": "kid-tenable-b5-04",
      "attestation_ref": "uri://slsa/attestations/patch-orchestration@sha256:tenable04"
    },
    "classification": "C2",
    "legal_hold": false
  },

```

```
"native_payload": { "...": "..." }  
}
```

Example: Consumed Protocol 5 — CMDB / Asset Graph (criticality & ownership)

[Informative]

Native payload

```
{  
  "asset_id": "srv-001",  
  "criticality": "CrownJewel",  
  "business_service": "Payments",  
  "owner_group": "payments.sre",  
  "environment": "production",  
  "region": "us-east-1",  
  "patch_sla_days": 7  
}
```

MCP-wrapped payload

```
{  
  "mcp_context": {  
    "mcp_version": "0.9",  
    "mission_id": "uuid-b5-cmdb-5555-6666-7777-8888",  
    "thread_id": "uuid-cmdb-srv-001",  
    "task_id": "uuid-9911-8822-7733-6644",  
    "role": "PatchOrchestrationAgent",  
    "intent": "implement",  
    "policy_refs": ["SI-2", "CM-2", "CM-6"],  
    "constraints": ["hitl_required:crown_jewel", "change_window:offhours", "region:us-east-1"],  
    "decision_basis": {  
      "evidence_refs": ["uri://cmdb/assets/srv-001"],  

```

```

    "confidence": 0.97,
    "explanation_ref": "uri://kb/patching/criticality-weighting"
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/patch-orchestration-agent",
    "signing_kid": "kid-cmdb-b5-05",
    "attestation_ref": "uri://slsa/attestations/patch-orchestration@sha256:cmdb05"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Outputs (native) [Informative]

- **Patch jobs** to WSUS/Intune/MDM; Yum/DNF/Apt/Zypper; Chocolatey/Winget; K8s Helm/Container rebuilders.
- **PatchOutcome** events including verification evidence (package versions, re-scan deltas).

MCP context (required) [Informative]

mission_id; role="PatchOrchestrationAgent"; intent="implement"; policy_refs;
 decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID,
 signing KID, attestation)

MCP context (optional) [Informative]

constraints (e.g., sla_days:N, hitl_required:*, change_window:*, region:*,
 canary_required:true); classification; legal_hold

Enforcement note [Informative]

PEPs in orchestrators **MUST** verify **ChangeApproval** (from B4) for prod, validate provenance.attestation, honor constraints (window/region/HITL/canary), and reject jobs lacking required tokens.

NIST SP 800-160v2 linkage [Informative]

Implement & Maintain — flaw remediation planning, execution, and verification consistent with resilient operations.

Automation feasibility [Informative]

High: end-to-end automation with HITL gates for risky patches (kernel/DB/CrownJewel, reboots).

Output Contracts (merged) [Informative]

OC-1: PatchJobDispatch (Orchestrator Job) [Informative]

- **Producer(s):** B5
- **Topic/Path:** POST /orchestrator/patch/jobs (WSUS/Intune/MDM/pkgmgr/Helm/ImageBuilder)
- **Schema/Format:** PatchJob@1.1 with fields: job_id, targets{asset_ids|selectors}, packages[{name, target_version, cve_ids[], kb_id?}], channel{wsus|apt|dnf|helm|image}, prechecks[], reboot_policy{required|never|if_needed}, approvals{ChangeApproval_id}, canary{size, criteria}, window, constraints[], evidence_refs[], policy_refs[], provenance
- **Classification:** C2 (C3 if package sources or image digests expose sensitive details)
- **Delivery:** exactly-once per job_id (receiver enforces idempotency)
- **Ordering:** per target group
- **Idempotency-Key:** sha256(job_id)
- **Ack/Nack:** 201 Created + job_handle; NACK on validation/policy failure
- **Timeouts/Retry:** ack<=60s; retry<=5; on repeated NACK open deferral ticket and emit PatchOutcome(status="rejected")
- **HITL Token:** required for kernel/DB/CrownJewel or where policy mandates
- **Observability:** trace_id, mission_id, job_handle, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PatchJob@1.1 | json_schema_uri=uri://schema/patch-job-1.1.json | sha256= | producers=B5 | consumers={WSUS-01,Intune-01,MDM-01,Apt-01,DNF-01,Helm-01,ImageBuilder-01} | accepts=1.0–1.1

Conformance: Normative.

OC-2: PatchOutcome (Verification Event) [Informative]

- **Producer(s):** B5 (and/or orchestrators, republished by B5)
- **Topic/Path:** kafka://sec.patch.outcome.v1
- **Schema/Format:** PatchOutcome@1.0 with fields: outcome_id, job_id, asset_uid, status{success|partial|failed|rejected|deferred}, installed[{name, version}], removed[], remaining_vulns_delta[{cve_id, before, after}], reboot_status, verification_evidence_refs[], rescans[{platform, before, after, ts}], window_used, duration_s, policy_refs[], provenance
- **Classification:** C2
- **Delivery:** at-least-once (consumers dedupe outcome_id)
- **Ordering:** per job_id then asset_uid
- **Idempotency-Key:** sha256(job_id, asset_uid, status, verification_hash)
- **Ack/Nack:** broker ACK; NACK → dead-letter
- **Timeouts/Retry:** broker-configured; retry<=5
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-2) [Normative]

Requirement Level: Required

Condition: Always

schema_id=PatchOutcome@1.0 | json_schema_uri=uri://schema/patch-outcome-1.0.json | sha256= | producers=B5 | consumers={SIEM-01,IR-01,GRC-01,CMDB-01}

Conformance: Normative.

OC-3: PatchWavePlan (Scheduling/Canary Plan) [Informative]

- **Producer(s):** B5
- **Topic/Path:** POST /orchestrator/patch/waves
- **Schema/Format:** PatchWavePlan@1.0 with fields: plan_id, change_intent_id?, waves[{name, targets, window, canary{size, criteria}, halt_conditions[], success_criteria[], rollback_plan_ref}], evidence_refs[], policy_refs[], provenance
- **Classification:** C2
- **Delivery:** exactly-once per plan_id
- **Ordering:** per plan_id
- **Idempotency-Key:** sha256(plan_id)
- **Ack/Nack:** 201 Created; NACK if conflicts with ChangeApproval or window
- **Timeouts/Retry:** ack<=30s; retry<=5; on failure downgrade to manual scheduling
- **HITL Token:** optional (prod canary > threshold)
- **Observability:** trace_id, mission_id, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When canary_required=true OR wave-based rollout is configured
 schema_id=PatchWavePlan@1.0 | json_schema_uri=uri://schema/patch-wave-plan-1.0.json | sha256= | producers=B5 | consumers={Orch-01}

Conformance: Normative when condition is met.

OC-4: RebootSchedule (Windows/Linux Reboot Coordination) [Informative]

- **Producer(s):** B5
- **Topic/Path:** POST /orchestrator/reboots
- **Schema/Format:** RebootSchedule@1.0 with fields: schedule_id, job_id, assets[], valid_from, valid_until, coordination_tokens[], maintenance_window, notifications{owner_group}, evidence_refs[], policy_refs[], provenance
- **Classification:** C2
- **Delivery:** exactly-once per schedule_id

- **Ordering:** per job_id
- **Idempotency-Key:** sha256(schedule_id)
- **Ack/Nack:** 201 Created; NACK on conflict with calendar freeze or missing approvals
- **Timeouts/Retry:** ack<=30s; retry<=5; escalate to B4 if repeated NACK
- **HITL Token:** required when CrownJewel or customer-facing clusters
- **Observability:** trace_id, mission_id
- **Retention/TTL:** >= 1 year (ops), >= 7 years (audit if CrownJewel)

Schema Capsule (OC-4) [Normative]

Requirement Level: Conditionally Required

Condition: When reboot_required=true in KB/advisory and assets are in-scope
 schema_id=RebootSchedule@1.0 | json_schema_uri=uri://schema/reboot-schedule-1.0.json | sha256= | producers=B5 | consumers={Orch-01,ITSM-01}

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, triaging_cves, correlating_assets, planning, scheduling, dispatching, executing, verifying, rescanning, rolled_back, deferred, failed, closed }

transition(idle -> triaging_cves) when CVE/KB/advisory ingested

transition(triaging_cves -> correlating_assets) when CPE/OVAL mapped to assets

transition(correlating_assets -> planning) when priority & scope computed

transition(planning -> scheduling) when wave/canary/reboot windows prepared

transition(scheduling -> dispatching) when ChangeApproval present (prod) OR non-prod

transition(dispatching -> executing) when job accepted by orchestrator

transition(executing -> verifying) when job completes

transition(verifying -> rescanning) when verification requires vuln re-scan

transition(rescanning -> closed) when remaining_vulns_delta <= thresholds

transition(executing|verifying -> rolled_back) on failure with rollback invoked

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

transition(planning|scheduling -> deferred) when freezes/conflicts or HITL blocks

transition(* -> failed) on policy/attestation errors or hard NACK

idempotency_key(PatchJob) = sha256(job_id)

idempotency_key(PatchOutcome) = sha256(job_id, asset_uid, status, verification_hash)

idempotency_key(WavePlan) = sha256(plan_id)

idempotency_key(RebootSched) = sha256(schedule_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 PatchJobDispatch	Required	Always	Executes governed patching
OC-2 PatchOutcome	Required	Always	Verifies remediation & closes the loop
OC-3 PatchWavePlan	Conditionally Required	canary_required=true or wave rollout configured	Safe staged rollout
OC-4 RebootSchedule	Conditionally Required	KB/advisory indicates reboot_required=true	Coordinated service recovery

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** SI-2 Flaw Remediation; RA-5 Vulnerability Scanning; CM-6 Configuration Settings; internal patch SLAs.

- **HITL required:** kernel or DB patches on **CrownJewels**; reboot-required in customer-facing windows; canary size above threshold; region-restricted assets; when ChangeApproval missing or expired.
- **Manual outside agent:** emergency deferral/waiver; moratorium overrides.

SLOs and KPIs [Informative]

- **TimeToPatch_p95 (Critical, KEV) <= 7 days**
- **VerificationEvidence_coverage >= 99.5 percent**
- **PatchFailureRollback_p95 <= 15 min**
- **ResidualRiskDelta_7d (critical vulns) >= 90 percent reduction**
- **FalseSuccessRate_30d <= 0.5 percent**

Outputs index [Informative]

[OC-1 PatchJobDispatch], [OC-2 PatchOutcome], [OC-3 PatchWavePlan], [OC-4 RebootSchedule]

Technical Implementation Details (B5) [Informative]

Model and training profile [Informative]

model_id=patch-orchestrator-model; temperature=0.0; max_tokens_out=400
prompt_pack_id=patch-priority-v1 (CVE/KEV + asset criticality rubric)
RAG: sources={NVD/KEV, OVAL/USN/RHSA, MSRC KB, vuln platform history, CMDB criticality, CAB calendars}; max_docs=16; min_similarity=0.80; citations required
fine_tuning/adapters: none initially; evaluate on prioritization accuracy and outcome prediction
guardrails: require ChangeApproval for prod; deny outside change_window; enforce region data locality

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency_then_importance
episodic_memory: per mission_id patch ledger (jobs, outcomes, rescans); ttl=7y
semantic_memory: namespaces=["cve","advisories","kb","assets","history"];
embeddings=text-embedding-sec-v1; k=16
durable_state_store: event-sourced journal; snapshot daily
consistency: exactly-once per job_id (dispatch); at-least-once for outcomes
idempotency: per Output Contracts

Decision and routing logic [Informative]

exploit_boost = 1.0 if in_kev else 0.3*threat_intel_signal

exposure = 1.0 if internet_exposed else 0.5 if dmz else 0.2

criticality = 1.0 if CrownJewel else 0.6 if Tier1 else 0.3

patch_priority_score = 0.35*cvss_norm + 0.25*exploit_boost + 0.20*criticality
+ 0.10*exposure + 0.10*age_norm

path = if env!="prod" and patch_priority_score >= 0.5 and window_ok then "dispatch"
else if env=="prod" and ChangeApproval_valid and window_ok then "dispatch"
else "defer_or_request_approval"

deadline = ingest_ts + sla_days(policy, severity, kev_flag)

Model Risk Management [Informative]

continuous_validation: daily replay of historic patches; adversarial tests (supersedence traps, ambiguous OVAL tests)

thresholds: prioritization_accuracy_7d >= 99.5 percent → auto_HITL if below

red_team_cycle: monthly tests for forged advisories and false KBs

rollback_policy: revert rulepack if PatchFailureRate increases by >= 1.5 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: why prioritized, target scope, risk & exposure, approvals, canary, reboot policy, evidence_refs

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; stable field order; retention per legal_hold

Incident Response Integration [Informative]

if related incident or active exploitation, escalate priority and coordinate with IR; emit PatchOutcome to SIEM and link to case.

Stakeholder Feedback Loop [Informative]

collect owner approvals/feedback on waves and reboots; feed rubric updates after governance review (no auto-training on regulated scans).

Data Sovereignty and Legal Hold [Informative]

enforce region on job execution and artifact storage; legal_hold=true → override TTL and freeze artifacts.

Interfaces (links only) [Informative]

Consumes: CVE/KB/advisories; vuln platform; CMDB/Asset Graph

Produces: OC-1 PatchJobDispatch; OC-2 PatchOutcome; OC-3 PatchWavePlan; OC-4 RebootSchedule

Safety and abuse prevention [Informative]

kill_switch on invalid approval tokens or signature mismatch; cap concurrent patches per service; sandbox canaries before broad rollout.

Testing and validation [Informative]

contract tests for all OCs; supersedence resolution tests; dry-run wave plans; reboot coordination simulations.

Deployment and lifecycle [Informative]

scale by fleet segment; canary rulepack updates; SBOM + attestations; sign all outputs.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (SI-2, RA-5, CM-6); NIST SP 800-40; NIST SP 800-137; NIST CSF 2.0 (PR.IP, DE.CM); ISO/IEC 27002:2022; CIS Benchmarks; CISA KEV program

MCP-Native Protocol Specification (B5) [Normative]

- **Native Protocol(s) Consumed:** CVE feeds; KB feeds; Vendor advisories (OVAL/JSON); Vulnerability platform REST; CMDB/Asset Graph
- **Native Protocol(s) Produced:** Patch jobs to orchestrators; PatchOutcome events; optional PatchWavePlan and RebootSchedule
- **MCP Context Fields:**

- **Required:** mission_id; role="PatchOrchestrationAgent"; intent="implement"; policy_refs; decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, KID, attestation)
- **Optional:** constraints (sla_days, hitl_required, change_window, region, canary_required); classification; legal_hold
- **Enforcement Note:** Orchestrators MUST verify provenance, **ChangeApproval** for prod, constraint compliance, and signatures on job requests/outcomes.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; see Schema Capsules for accepted ranges/EOL.
- **Example payloads:** native and MCP-wrapped (authoritative above).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is **[Normative]** and, together with each **Schema Capsule**, defines testable requirements.

B6. Vulnerability Scanning Agent

Agent Blueprint [Informative]

Purpose: Execute authenticated/unauthenticated host, container, and app scans; evaluate misconfigurations; emit **VulnFinding** events and optional **ExemptionRequest** records; store scan logs/artifacts for audit and triage.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **CMDB / Asset Graph:** target scoping (env, platform, tags like internet_facing, crown_jewel), ownership, maintenance tier.
- **PAM / Secrets Manager:** JIT ephemeral credentials/tokens with tight scopes and TTLs.
- **Scanner Templates and/or SCAP (XCCDF/OVAL):** policy profiles for plugin sets, ports, safe checks, and compliance mappings.

Model training / knowledge (what the LLM relies on):

- **Scan-planning rulepack:** how to choose auth vs unauth, template selection by platform, rate-limits by segment, off-hours scheduling rules.

- **RAG sources:** scanner template catalog, historical scan outcomes and false-positive labels, CMDB service criticality, KEV/EPSS reference data. Do not train on regulated scan artifacts; use evidence_refs to fetch on demand.
- **Guardrails:** safe_scripts_only default; command allowlists for credential scopes; deny scans outside scan_window; region data-locality enforcement; no persistent secrets.

Decisions it makes (deterministic + model-assisted):

- **Target and template selection:** which assets to scan; choose policy (e.g., linux-authenticated-standard, windows-gpo, container-image).
- **Auth vs unauth mode:** prefer authenticated when creds available and risk acceptable; fall back to unauth or defer to HITL for CrownJewels.
- **Scheduling and rate control:** off-hours windows, pps limits per subnet, wave-based execution to avoid brownouts.
- **Finding dedup and enrichment:** normalize plugin output; attach CVE/CWE, CVSS, KEV, EPSS; correlate to business service/criticality.
- **Exemption suggestion:** propose ExemptionRequest when compensating controls exist or exploitability is near-zero with strong justification.

Routing / where outputs go:

- **VulnFinding** → Kafka/AMQP topic or REST sink for vuln platform/SIEM; CMDB linkage update.
- **ExemptionRequest** → GRC/ticketing system for HITL approval; auto-link to findings.
- **Scan artifacts/logs** → object storage bucket with retention tags; artifact_ref attached to findings.

Automation scope vs. manual/HITL:

- **Fully automated:** target expansion from CMDB filters; creds brokering with TTL; scheduling; execution; enrichment; artifact upload.
- **HITL required:** authenticated scans on **CrownJewels** during on-hours; intrusive checks beyond safe_scripts_only; exemptions accepting high-risk vulns.
- **Manual outside agent:** business risk acceptance beyond policy thresholds; red-team coordination scans; exception window overrides.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **CMDB / Asset Graph (REST/GraphQL)** — target list and scoping
2. **PAM / Secrets Manager (REST/gRPC)** — JIT scan credentials or ephemeral tokens
3. **Scanner Templates (REST/JSON) and/or SCAP (XCCDF/OVAL over HTTPS/SSH)** — scan policies

Example: Consumed Protocol 1 — CMDB / Asset Graph (target selection)

[Informative]

Native payload

```
{
  "query_id": "targets-2025-08-15-01",
  "filters": {
    "environment": "production",
    "platform_in": ["linux", "windows"],
    "tags_any": ["internet_facing", "crown_jewel"]
  },
  "result": [
    {"asset_id": "srv-001", "ip": "10.2.14.5", "platform": "linux"},
    {"asset_id": "win-srv-02", "ip": "10.2.18.11", "platform": "windows"}
  ],
  "generated_at": "2025-08-15T12:05:00Z"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b6-cmdb-1111-2222-3333-4444",
  }
}
```

```

"thread_id": "uuid-targets-2025-08-15-01",
"task_id": "uuid-aa11-bb22-cc33-dd44",
"role": "VulnerabilityScanningAgent",
"intent": "assess",
"policy_refs": ["RA-5", "CM-8"],
"constraints": ["scan_window:offhours", "rate_limit_pps:500", "region:us-east-1"],
"decision_basis": {
  "evidence_refs": ["uri://cmdb/query/targets-2025-08-15-01"],
  "confidence": 0.98
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/vuln-scanning-agent",
  "signing_kid": "kid-cmdb-b6-01",
  "attestation_ref": "uri://slsa/attestations/vuln-scan@sha256:cmdb01"
},
"classification": "C2",
"legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 2 — PAM / Secrets Manager (ephemeral credential lease) [Informative]

Native payload

```

{
  "lease_id": "lease-7c1a",
  "principal": "scanner/linux-prod",
  "type": "ssh_password",

```

```

"username": "scan_jit",
"secret_ref": "vault://kv/scanner/linux-prod/lease-7c1a",
"ttl_seconds": 1800,
"scope": {"assets": ["srv-001"], "commands_allowlist":
["stat","cat","dpkg","rpm","wmic"]}
}
MCP-wrapped payload
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b6-pam-2222-3333-4444-5555",
    "thread_id": "uuid-lease-7c1a",
    "task_id": "uuid-ee11-ff22-0011-2233",
    "role": "VulnerabilityScanningAgent",
    "intent": "assess",
    "policy_refs": ["IA-5", "RA-5"],
    "constraints": ["safe_scripts_only:true", "ttl<=1800s", "no_persist_secret:true"],
    "decision_basis": {
      "evidence_refs": ["vault://kv/scanner/linux-prod/lease-7c1a"],
      "confidence": 0.99,
      "explanation_ref": "uri://kb/scanning/authenticated-vs-unauthenticated"
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/vuln-scanning-agent",
      "signing_kid": "kid-pam-b6-02",
      "attestation_ref": "uri://slsa/attestations/vuln-scan@sha256:pam02"
    },
  },

```

```

    "classification": "C3",
    "legal_hold": false
  },
  "native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 3 — Scanner Templates and/or SCAP [Informative]

3A) Native payload (scanner policy JSON)

```

{
  "template_id": "linux-authenticated-standard",
  "plugins": ["cves", "weak_crypto", "kernel", "packages"],
  "ports": "T:22,443,U:161",
  "safe_checks": true,
  "timeout_seconds": 3600,
  "compliance_profiles": ["cis_linux_l1_1.0.0"]
}

```

3A) MCP-wrapped payload

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b6-templ-3333-4444-5555-6666",
    "thread_id": "uuid-template-linux-authenticated-standard",
    "task_id": "uuid-4411-5522-6633-7744",
    "role": "VulnerabilityScanningAgent",
    "intent": "assess",
    "policy_refs": ["RA-5", "CM-6", "CIS-Linux-L1-1.0.0"],
    "constraints": ["safe_scripts_only:true"],
    "decision_basis": {

```

```

    "evidence_refs": ["uri://scanner/templates/linux-authenticated-standard"],
    "confidence": 0.96
  },
  "provenance": {
    "producer_spiffe": "spiffe://enterprise/security/vuln-scanning-agent",
    "signing_kid": "kid-template-b6-03",
    "attestation_ref": "uri://slsa/attestations/vuln-scan@sha256:templ03"
  },
  "classification": "C1",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

3B) Native payload (SCAP XCCDF profile fragment)

```

<Profile id="cis_linux_l1_1.0.0">
  <title>CIS Linux Level 1 v1.0.0</title>
  <select idref="xccdf_rule_ssh_permitrootlogin_no" selected="true"/>
  <select idref="xccdf_rule_nodev_on_tmp" selected="true"/>
</Profile>

```

3B) MCP-wrapped payload (SCAP)

```

{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b6-scap-7777-8888-9999-0000",
    "thread_id": "uuid-xccdf-cis_linux_l1_1.0.0",
    "task_id": "uuid-abcd-ef01-2345-6789",
    "role": "VulnerabilityScanningAgent",

```

```

"intent": "assess",
"policy_refs": ["RA-5", "CIS-Linux-L1-1.0.0"],
"constraints": ["scan_window:offhours"],
"decision_basis": {
  "evidence_refs": ["uri://scap/profiles/cis_linux_l1_1.0.0"],
  "confidence": 0.94
},
"provenance": {
  "producer_spiffe": "spiffe://enterprise/security/vuln-scanning-agent",
  "signing_kid": "kid-scap-b6-04",
  "attestation_ref": "uri://slsa/attestations/vuln-scan@sha256:scap04"
},
"classification": "C1",
"legal_hold": false
},
"native_payload": "<Profile id=\"cis_linux_l1_1.0.0\">...</Profile>"
}

```

Outputs (native) [Informative]

- **VulnFinding** (Kafka/AMQP/REST) with CVSS/CWE/KEV/EPSS enrichment and artifact_ref.
- **ExemptionRequest** (REST to GRC/ticketing) for proposed/approved exceptions.
- **Scan logs/artifacts** (object storage) with retention tags and immutable checksums.

MCP context (required) [Informative]

mission_id; role="VulnerabilityScanningAgent"; intent="assess"; policy_refs;
 decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID,
 signing KID, attestation)

MCP context (optional) [Informative]

constraints (scan_window, rate_limit_pps, safe_scripts_only, region, no_auth_scan_in_prod); classification; legal_hold

Enforcement note [Informative]

PEPs must verify provenance.attestation and enforce constraints before executing scans; GRC systems must require HITL approval for **ExemptionRequest** beyond defined thresholds or impacting CrownJewels.

NIST SP 800-160v2 linkage [Informative]

Evaluate — structured technical verification; **Maintain Awareness** via continuous assessment. Also aligns with **NIST SP 800-115** methodology.

Automation feasibility [Informative]

High: policy-driven scheduling, credential brokering, execution, enrichment, and artifact handling.

Output Contracts (merged) [Informative]

OC-1: VulnFinding (Normalized Finding Event) [Informative]

- **Producer(s):** B6
- **Topic/Path:** kafka://sec.vuln.finding.v1 or POST /vuln/findings
- **Schema/Format:** VulnFinding@1.1 with fields: finding_id, asset_id, ip, platform, scanner_policy_id, cve_ids[], cwe_ids[], cvss{base, vector}, kev{bool, source}, epss{score}, severity, title, description_ref, detection_ts, first_seen_ts, evidence_refs[], artifact_ref?, remediation{action, kb_or_package?, config_fix?}, triage_status{new|in_review|accepted_risk|false_positive|fixed}, policy_refs[], provenance
- **Classification:** C2
- **Delivery:** at-least-once (consumers dedupe by finding_id)
- **Ordering:** per asset_id
- **Idempotency-Key:** sha256(asset_id, cve_id, scanner_policy_id)
- **Ack/Nack:** broker ACK or 201; NACK → dead-letter with reason
- **Timeouts/Retry:** broker-configured; retry<=5
- **HITL Token:** none

- **Observability:** trace_id, mission_id, enrichment_flags{kev,epss}, provenance
- **Retention/TTL:** >= 7 years

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=VulnFinding@1.1 | json_schema_uri=uri://schema/vuln-finding-1.1.json | sha256= | producers=B6 | consumers={VulnPlat-01,SIEM-01,IR-01,CMDB-01} | accepts=1.0–1.1

Conformance: Normative.

OC-2: ExemptionRequest (Risk Acceptance / False Positive Appeal) [Informative]

- **Producer(s):** B6 (initiates) and/or Owners (via portal)
- **Topic/Path:** POST /grc/exemptions
- **Schema/Format:** ExemptionRequest@1.0 with fields: request_id, finding_refs[], reason{false_positive|operational_constraint|compensating_control}, justification, compensating_controls[], requested_until, owner_group, approvals_chain[], policy_refs[], provenance
- **Classification:** C2+
- **Delivery:** exactly-once per request_id
- **Ordering:** per request_id
- **Idempotency-Key:** sha256(request_id)
- **Ack/Nack:** 201 Created with case_id; NACK on missing approvals or invalid scope
- **Timeouts/Retry:** ack<=30s; retry<=5; escalate to HITL on repeated NACK
- **HITL Token:** required for CrownJewel or high-severity exemptions
- **Observability:** trace_id, mission_id, decision_rationale_url, provenance
- **Retention/TTL:** >= 7 years (or legal_hold)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When exemption workflow is enabled or a finding meets exemption criteria
schema_id=ExemptionRequest@1.0 | json_schema_uri=uri://schema/exemption-

request-1.0.json | sha256= | producers=B6 | consumers={GRC-01,Ticket-01}

Conformance: Normative when condition is met.

OC-3: ScanArtifactUpload (Evidence Archive) [Informative]

- **Producer(s):** B6 or scanner engines (ingested by B6)
- **Topic/Path:** s3://sec-scan-artifacts/<mission_id>/<run_id>/... (PUT)
- **Schema/Format:** ScanArtifact@1.0 manifest: run_id, assets_scanned[], policy_id, started_ts, finished_ts, files[{path, sha256, size}], storage_class, retention_ttl, classification, provenance
- **Classification:** C2 (C3 if sensitive outputs)
- **Delivery:** at-least-once (object storage guarantees + manifest)
- **Ordering:** none
- **Idempotency-Key:** sha256(run_id)
- **Ack/Nack:** 200 OK; NACK on checksum mismatch
- **Timeouts/Retry:** exponential backoff; retry<=5
- **HITL Token:** none
- **Observability:** trace_id, mission_id, provenance
- **Retention/TTL:** per data governance; override on legal_hold

Schema Capsule (OC-3) [Normative]

Requirement Level: Conditionally Required

Condition: When artifact_retention policy is enabled or audit evidence is mandated
schema_id=ScanArtifact@1.0 | json_schema_uri=uri://schema/scan-artifact-1.0.json |
sha256= | producers=B6 | consumers={IR-01,Audit-01,VulnPlat-01}

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, planning, credentialing, scheduling, executing_scan, parsing, enriching,
emitting_findings,

uploading_artifacts, awaiting_exemption_approval, deferred, failed, closed }

transition(idle -> planning) when CMDB target set received
 transition(planning -> credentialing) when auth scan selected
 transition(credentialing -> scheduling) when lease issued
 transition(planning|credentialing -> scheduling) when unauth scan
 transition(scheduling -> executing_scan) when window opens and rate_limit ok
 transition(executing_scan -> parsing) when engine completes
 transition(parsing -> enriching) when raw findings normalized
 transition(enriching -> emitting_findings) when KEV/EPSS attached
 transition(emitting_findings -> uploading_artifacts) when artifacts present
 transition(enriching -> awaiting_exemption_approval) when agent proposes
 ExemptionRequest
 transition(* -> deferred) on freeze/window conflict or owner request
 transition(* -> failed) on provenance/attestation error or artifact checksum mismatch
 transition(enriching|awaiting_exemption_approval -> closed) when outputs emitted and
 SLAs met

idempotency_key(VulnFinding) = sha256(asset_id, cve_id, scanner_policy_id)

idempotency_key(ExemptionReq) = sha256(request_id)

idempotency_key(ScanArtifact) = sha256(run_id)

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 VulnFinding	Required	Always	Drives remediation and risk view
OC-2 ExemptionRequest	Conditionally Required	Exemption workflow enabled or criteria met	Governance & contestability

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-3 ScanArtifactUpload	Conditionally Required	Artifact retention or audit evidence mandated	Forensics and audit trail

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

- **policy_refs:** RA-5 Vulnerability Scanning; CM-6 Configuration Settings; IA-5 Authenticator Management; internal scanning SOPs.
- **HITL required:** intrusive checks on **CrownJewels**; exemptions on Critical findings; scanning outside off-hours; scans exceeding pps thresholds.
- **Manual outside agent:** executive risk acceptance; emergency moratorium overrides.

SLOs and KPIs [Informative]

- **ScanCoverage_p95 (scheduled targets) >= 99 percent**
- **TimeToFinding_p95 (from window open) <= 2 h**
- **AuthScanSuccessRate_7d >= 98 percent**
- **FalsePositiveRate_30d <= 1 percent**
- **ArtifactUploadSLA_p95 <= 10 min**

Outputs index [Informative]

[OC-1 VulnFinding], [OC-2 ExemptionRequest], [OC-3 ScanArtifactUpload]

Technical Implementation Details (B6) [Informative]

Model and training profile [Informative]

model_id=vuln-scan-planner; temperature=0.0; max_tokens_out=300
prompt_pack_id=vuln-scan-v1 (scan-planning rubric, safe-checks policies)
RAG: sources={scanner policies, SCAP profiles, KEV/EPSS refs, CMDB service map, historical outcomes}; max_docs=12; min_similarity=0.80; citations required
fine_tuning/adapters: none initially; evaluate on plan selection accuracy and false-positive reduction
guardrails: safe_scripts_only=true default; deny outside scan_window; region-scoped data flows; no secret persistence

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency_then_importance
episodic_memory: per mission_id run journal (targets, leases, outcomes); ttl=365d (>= 7y for audit indices only)
semantic_memory: namespaces=["templates","scap","assets","history"];
embeddings=text-embedding-sec-v1; k=12
durable_state_store: event-sourced journal with daily snapshots
consistency: at-least-once for findings; exactly-once for exemption requests
idempotency: per Output Contracts

Decision and routing logic [Informative]

kev_flag = is_in_kev(cve_id) ? 1 : 0

epss_norm = clamp(epss_score, 0, 1)

exposure = 1.0 if asset.internet_facing else 0.6 if asset.dmz else 0.2

criticality = 1.0 if asset.crown_jewel else 0.6 if asset.tier1 else 0.3

last_scan_age_norm = clamp(days_since_last_scan / 30, 0, 1)

scan_priority_score = 0.30*criticality + 0.25*kev_flag + 0.20*epss_norm
+ 0.15*exposure + 0.10*last_scan_age_norm

auth_mode = (creds_available && safe_scripts_only) ? "authenticated" :
"unauthenticated"

rate_limit_pps = min(policy_max_pps, segment_pps_budget)

exemption_candidate = (severity in {Low, Medium} && compensating_controls_strong)

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Model Risk Management [Informative]

continuous_validation: daily replay on goldens; adversarial tests for credential leakage and command injection

thresholds: false_positive_rate_7d $\leq$ 1 percent $\rightarrow$ auto_HITL if breached

red_team_cycle: monthly probes for unsafe plugin selection or scan window violations

rollback_policy: revert template/rulepack if AuthScanSuccessRate drops by $\geq$ 2 percentage points for 48 h

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: target scope, template chosen, auth mode, rate limits, evidence_refs, enrichment flags (KEV/EPSS)

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL with stable field order; retention per classification and legal_hold

Incident Response Integration [Informative]

auto-tag findings linked to active incidents; burst-scan hot segments under IR control with stricter pps; stream VulnFinding to SIEM.

Stakeholder Feedback Loop [Informative]

owners can mark false_positive or accept_risk; agent emits ExemptionRequest for approval; feedback influences template selection after governance review (no auto-training on regulated artifacts).

Data Sovereignty and Legal Hold [Informative]

enforce region on scan execution and artifact storage; legal_hold=true $\rightarrow$ TTL override and purge blocks.

Interfaces (links only) [Informative]

Consumes: CMDB/Asset Graph; PAM/Secrets Manager; Scanner Templates/SCAP

Produces: OC-1 VulnFinding; OC-2 ExemptionRequest; OC-3 ScanArtifactUpload

Safety and abuse prevention [Informative]

kill_switch on provenance or lease misuse; cap concurrent scans per subnet; sandbox dry-runs; strict allowlists for command execution.

Testing and validation [Informative]

contract tests for all OCs; safe-scripts enforcement tests; SCAP profile conformance; artifact checksum and retention tests.

Deployment and lifecycle [Informative]

horizontal scaling by segment; canary new templates; SBOM + attestations; sign outputs; scheduled rulepack updates.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-115; NIST SP 800-53 Rev. 5 (RA-5, CM-6, IA-5); NIST CSF 2.0 (DE.CM, PR.IP); SCAP (XCCDF/OVAL); CVSS v3.1; FIRST EPSS; CISA KEV; CIS Benchmarks

MCP-Native Protocol Specification (B6) [Normative]

- **Native Protocol(s) Consumed:** CMDB/Asset Graph; PAM/Secrets Manager; Scanner Templates and/or SCAP
- **Native Protocol(s) Produced:** VulnFinding; ExemptionRequest; ScanArtifactUpload
- **MCP Context Fields:**
 - **Required:** mission_id; role="VulnerabilityScanningAgent"; intent="assess"; policy_refs; decision_basis (evidence_refs, confidence, explanation_ref); provenance (SPIFFE ID, KID, attestation)
 - **Optional:** constraints (scan_window, rate_limit_pps, safe_scripts_only, region, no_auth_scan_in_prod); classification; legal_hold
- **Enforcement Note:** Execution PEPs MUST verify provenance, constraints, and region locality; GRC MUST enforce HITL for high-risk exemptions and CrownJewel impacts.
- **Versioning and compatibility; producers/consumers registry:** authoritative in schema registry; accept ranges per Schema Capsules.
- **Example payloads:** native and MCP-wrapped (authoritative in this card).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

B7. Risk Prioritization Agent

Agent Blueprint [Informative]

Purpose: Rank and queue remediation by combining **VulnFinding** with exploitability (CTI/KEV/EPSS), attack exposure (ASM), and business impact (CMDB), producing a **RemediationQueue** with reasons and weights; emit an explainable **PrioritizationReport** for approvers and audit.

Operational Narrative [Informative]

Inputs used (authoritative sources):

- **VulnFinding (Kafka/AMQP)** — normalized findings from B6; key fields: cve_id, severity/cvss, epss, kev, asset_id, detection timestamps, remediation hints.
- **STIX/TAXII + CISA KEV JSON (Intel/KEV)** — labels like exploited-in-the-wild, ransomware linkage; KEV due_date.
- **ASM Exposure (REST/GraphQL)** — internet_facing, public DNS, open ports, TLS issues, exposure_score.
- **CMDB / Business Impact (REST/GraphQL)** — criticality tier, RTO/RPO, data classification tags (PCI/PHI/PII), monthly_revenue_at_risk_usd, owner_group.

Model training / knowledge (what the LLM relies on):

- **Priority policy rulepack:** mapping from org risk appetite to weights and caps (e.g., KEV > EPSS when ransomware campaigns active).
- **RAG sources:** historical remediation effectiveness, time-to-fix per team, false-positive archives, business impact registry; do **not** train on regulated artifacts—use evidence_refs.
- **Guardrails:** fairness caps by team, per-region data locality, SLA floors (e.g., KEV due_date), bounds on automatic reordering, monotonicity tests (higher risk_score must not be ranked lower unless fairness cap fires).

Decisions it makes (deterministic + model-assisted):

- **Risk scoring:** compute risk_score per finding/asset using multi-factor weighting (see Decision & routing logic).
- **Queue formation:** produce ordered **RemediationQueue** per team/env/region with canary hints and SLAs.

- **Explainability:** attach feature importances, rationale, and evidence_refs; open auto-appeal when model_confidence < threshold or stakeholder_disagreement_score >= 0.5.
- **Capacity & fairness:** throttle per owner_group to avoid starvation; elevate CrownJewels even when caps are hit.

Routing / where outputs go:

- **RemediationQueue** → Patch Orchestration (B5), Baseline Compliance (B2), Change Governance (B4); optional export to ticketing.
- **PrioritizationReport** → approver portals (GRC/Eng Mgmt), audit store; link to each queue snapshot.
- **Signals** → lightweight backpressure notices to upstream (optional) when queue length or SLA breach risk spikes.

Automation scope vs. manual/HITL:

- **Fully automated:** scoring, ranking, fairness application, queue emission, periodic refresh, report generation.
- **HITL required:** overrides on CrownJewel deprioritization, SLA extensions beyond policy, disputes where business impact metadata is stale/contested.
- **Manual outside agent:** authoritative changes to business impact (e.g., revenue at risk), policy updates to weighting scheme.

Security Domain: Asset, Configuration, and Change Management

Inputs (native protocols consumed) [Informative]

1. **Kafka / AMQP — VulnFinding (from B6)** — normalized vulnerability events
2. **STIX/TAXII & CISA KEV JSON — Intel/KEV** — exploit-in-the-wild and KEV due dates
3. **ASM Exposure (REST/GraphQL)** — external/internal exposure attributes
4. **CMDB / Business Impact (REST/GraphQL)** — criticality, RTO/RPO, data classification, revenue risk

Example: Consumed Protocol 1 — Kafka / AMQP (VulnFinding) [Informative]

Native payload

```
{
```

```
"finding_id": "VF-2025-08-15-0091",
"asset_id": "srv-001",
"cve_id": "CVE-2025-12345",
"cvss": 9.8,
"cwe": "CWE-22",
"first_seen": "2025-08-14T18:10:00Z",
"last_seen": "2025-08-15T10:20:00Z",
"auth_scan": true,
"fix": "Update httpd to 2.4.60+"
}
```

MCP-wrapped payload

```
{
  "mcp_context": {
    "mcp_version": "0.9",
    "mission_id": "uuid-b7-vf-1111-2222-3333-4444",
    "thread_id": "uuid-finding-VF-2025-08-15-0091",
    "task_id": "uuid-aa11-bb22-cc33-dd44",
    "role": "RiskPrioritizationAgent",
    "intent": "prioritize",
    "policy_refs": ["RA-5", "SI-2"],
    "decision_basis": {
      "evidence_refs": ["uri://kafka/vulnfindings/VF-2025-08-15-0091"],
      "confidence": 0.99
    },
    "provenance": {
      "producer_spiffe": "spiffe://enterprise/security/risk-prioritization-agent",
      "signing_kid": "kid-vf-b7-01",

```

```

    "attestation_ref": "uri://slsa/attestations/risk-priority@sha256:vf01"
  },
  "classification": "C2",
  "legal_hold": false
},
"native_payload": { "...": "..." }
}

```

Example: Consumed Protocol 2 — STIX/TAXII & CISA KEV JSON [Informative]
 2A) STIX indicator (native) and MCP-wrapped — exploited-in-the-wild flag (as provided in your prompt).

2B) KEV entry (native) and MCP-wrapped — includes due_date and ransomware linkage (as provided).

Example: Consumed Protocol 3 — ASM Exposure (REST/GraphQL) [Informative]
 Native and MCP-wrapped examples as provided (exposure_score, internet_facing).

Example: Consumed Protocol 4 — CMDB / Business Impact (REST/GraphQL) [Informative]
 Native and MCP-wrapped examples as provided (criticality, RTO/RPO, data_classification, revenue risk).

Outputs (native) [Informative]

- **RemediationQueue** (Kafka/AMQP/REST) — ordered queue segments per team/env/region with risk_score, SLA target, rationale, and canary hints.
- **PrioritizationReport** (REST) — snapshot of feature importances and per-item explanations; suitable for approvers/auditors.

MCP context (required) [Informative]

mission_id; role="RiskPrioritizationAgent"; intent="prioritize"; policy_refs; decision_basis (feature_weights, evidence_refs, explanation_ref); provenance (SPIFFE ID, signing KID, attestation)

MCP context (optional) [Informative]

constraints: sla_days:<n>, fairness_cap_per_team:<n>, region:<code>; classification; legal_hold

Enforcement note [Informative]

Downstream executors (B5/B2/B4) MUST verify **provenance.attestation** and honor **SLA and fairness** annotations; any **override** requires HITL and is appended as a queue override record.

NIST SP 800-160v2 linkage [Informative]

Evaluate & Maintain — risk-informed prioritization driving resilient remediation sequences.

Automation feasibility [Informative]

High: fully automatic ranking and queue emission; HITL only for overrides and contested impact metadata.

Output Contracts (merged) [Informative]

OC-1: RemediationQueue [Informative]

- **Producer(s):** B7
- **Topic/Path:** kafka://sec.remediation.queue.v1 or POST /remediation/queue
- **Schema/Format:** RemediationQueue@1.1 with items[queue_id, item_id, asset_id, cve_id, risk_score, rank, sla_due_ts, owner_group, canary_hint, fairness_bucket, rationale_url, policy_refs[], provenance]
- **Classification:** C2
- **Delivery:** at-least-once (consumers dedupe by item_id)
- **Ordering:** per owner_group and region
- **Idempotency-Key:** sha256(queue_id, item_id)
- **Ack/Nack:** broker ACK or 201; NACK → dead-letter + alert
- **Timeouts/Retry:** retry<=5; backoff exponential
- **HITL Token:** required for negative priority overrides on CrownJewels
- **Observability:** trace_id, mission_id, feature_weights_ref, kev_flag, epss_score, exposure_score, business_impact_ref
- **Retention/TTL:** >= 1 year

Schema Capsule (OC-1) [Normative]

Requirement Level: Required

Condition: Always

schema_id=RemediationQueue@1.1 | json_schema_uri=uri://schema/remediation-queue-1.1.json | sha256= | producers=B7 | consumers={B5,B2,B4,Ticket-01} | accepts=1.0–1.1

Conformance: Normative.

OC-2: PrioritizationReport (Explainability Snapshot) [Informative]

- **Producer(s):** B7
- **Topic/Path:** GET/POST /remediation/reports/{queue_id}
- **Schema/Format:** PrioritizationReport@1.0 with fields: queue_id, generated_ts, global_feature_weights, per_item_explanations[{item_id, shap_like_features[], decision_rationale, evidence_refs[]}], fairness_metrics, monotonicity_tests, overrides[]
- **Classification:** C2
- **Delivery:** exactly-once per queue_id per generation_ts
- **Ordering:** none
- **Idempotency-Key:** sha256(queue_id, generated_ts)
- **Ack/Nack:** 201 Created; NACK on schema fail
- **Timeouts/Retry:** ack<=30s; retry<=5
- **HITL Token:** none (read-only)
- **Observability:** trace_id, mission_id, policy_refs, provenance
- **Retention/TTL:** >= 3 years (or legal_hold)

Schema Capsule (OC-2) [Normative]

Requirement Level: Conditionally Required

Condition: When explainability is mandated by policy/regulation or an approver portal is in use

schema_id=PrioritizationReport@1.0 | json_schema_uri=uri://schema/prioritization-report-1.0.json | sha256= | producers=B7 | consumers={GRC-01, Audit-01, EngMgmt-01} | accepts=1.0

Conformance: Normative when condition is met.

State machine (concise) [Informative]

states = { idle, ingesting, enriching, scoring, fairness_applying, queue_emitting, reporting, monitoring_sla, deferred, failed, closed }

transition(idle -> ingesting) on new VulnFinding batch/window

transition(ingesting -> enriching) when CTI/ASM/CMDB lookups attached

transition(enriching -> scoring) when features complete

transition(scoring -> fairness_applying) when raw ranks computed

transition(fairness_applying -> queue_emitting) when caps and boosts applied

transition(queue_emitting -> reporting) when OC-1 persisted

transition(reporting -> monitoring_sla) when OC-2 generated (if required)

transition(* -> deferred) on data locality conflict or missing impact data

transition(* -> failed) on schema/provenance error

transition(monitoring_sla -> closed) on SLA satisfied or reassigned

Output Contracts Summary [Normative]

Output Contract	Requirement Level	Trigger Condition	Business Impact
OC-1 RemediationQueue	Required	Always	Drives execution order and SLAs
OC-2 PrioritizationReport	Conditionally Required	Explainability mandated or approver portal enabled	Approver trust, auditability, contestability

Requirement Level Definitions:

- **Required:** Must be implemented for conformant deployment
- **Conditionally Required:** Must be implemented when trigger condition is met
- **Optional:** May be implemented for enhanced functionality

Policies and HITL gates [Informative]

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

- **policy_refs:** SI-2 Flaw Remediation; RA-5 Vulnerability Scanning; PM-5 System-level risk management; internal risk appetite statements.
- **HITL required:** deprioritizing CrownJewels; SLA extensions beyond approved bounds; fairness override that starves any owner_group for more than 24 h.
- **Manual outside agent:** authoritative edits to CMDB impact and revenue risk.

SLOs and KPIs [Informative]

- **TimeToQueue_p95** <= 10 min from VulnFinding arrival
- **ExplainCoverage** >= 99 percent items with per-item rationale
- **MonotonicityViolations** == 0 per batch (except fairness-cap overrides, which must be logged)
- **SLAAdherence_7d** >= 98 percent for KEV-tagged items
- **DisputeResolution_p95** <= 5 business days

Outputs index [Informative]

[OC-1 RemediationQueue], [OC-2 PrioritizationReport]

Technical Implementation Details (B7) [Informative]

Model and training profile [Informative]

model_id=risk-priority-scorer; temperature=0.0; max_tokens_out=400
 prompt_pack_id=risk-priority-v1 (weighting policy, tie-break rules, fairness)
 RAG: sources={risk policy store, CTI/KEV notes, ASM exposure catalog, business impact registry, historical fix lead times}; max_docs=12; min_similarity=0.80
 fine_tuning/adapters: none initially; evaluate on rank agreement with approved baselines and SLA outcomes
 guardrails: enforce region locality; cap per-team queue share; prohibit demotions below SLA floor

Memory and state [Informative]

working_memory.max_tokens=2k; eviction=recency_then_importance
 episodic_memory: per mission_id queue snapshots; ttl=365d
 semantic_memory: namespaces=["risk-policy","cti-notes","impact-registry"];
 embeddings=text-embedding-sec-v1; k=12
 durable_state_store: event-sourced queue with snapshot per emission

consistency: at-least-once for OC-1; exactly-once for OC-2 per queue_id
idempotency: as per Output Contracts

Decision and routing logic [Informative]

Normalize inputs to 0..1

cvss_n = cvss / 10

epss_n = clamp(epss, 0, 1)

kev_flag = 1 if in_kev else 0

exp_n = exposure_score # already 0..1

crit_n = 1.0 if crown_jewel else 0.7 if tier1 else 0.4 if tier2 else 0.2

data_n = 1.0 if contains_any {PCI, PHI, PII} else 0.3

rto_n = clamp((1440 - rto_minutes) / 1440, 0, 1) # tighter RTO => higher risk

rev_n = clamp(log10(1 + revenue_at_risk_usd) / 10, 0, 1)

Base score

risk_score_raw =

0.22*cvss_n + 0.18*epss_n + 0.20*kev_flag +

0.15*exp_n + 0.12*crit_n + 0.06*data_n +

0.04*rto_n + 0.03*rev_n

SLA bump and staleness

sla_bump = 0.05 if now > kev_due_date else 0

stale_bump = clamp(days_open / 30, 0, 0.08)

risk_score = clamp(risk_score_raw + sla_bump + stale_bump, 0, 1)

Fairness application

cap_per_team = fairness_cap_per_team # e.g., 30 percent of queue window

Copyright © 2025 John M. Willis and Quantum Powered Security, Inc. • CC BY 4.0

Tie-breaks: earlier first_seen wins, then internet_facing, then lower remediation_effort.

Model Risk Management [Informative]

continuous_validation: daily backtests on historical batches; adversarial tests for gaming by under-reporting impact

thresholds: MonotonicityViolations > 0 → auto_HITL and freeze re-weighting

red_team_cycle: monthly tests on fairness starvation and SLA breach scenarios

rollback_policy: revert to last good weight set if SLAAdherence_7d < 95 percent

Transparency and Audit Trail (Approver/Auditor UX) [Informative]

decision_rationale_template: list per-item weighted features, KEV/EPSS flags, business impact fields, fairness effects

UI/API: expose classification_label, provenance.attestation, decision_rationale_url

audit_log_format: JSONL; stable field order; legal_hold overrides TTL

Incident Response Integration [Informative]

when related_incident present, boost items tied to the case; emit queue slices to IR workboards.

Stakeholder Feedback Loop [Informative]

owner feedback on mis-ranked items becomes labeled examples; changes require governance review; never auto-train on regulated artifacts.

Data Sovereignty and Legal Hold [Informative]

respect region constraint in data joins and queue export; legal_hold=true → retain reports and snapshots.

Interfaces (links only) [Informative]

Consumes: VulnFinding; STIX/TAXII and KEV; ASM Exposure; CMDB/Business Impact

Produces: OC-1 RemediationQueue; OC-2 PrioritizationReport

Safety and abuse prevention [Informative]

kill_switch on provenance failure or fairness starvation; anti-gaming checks for manipulated impact fields.

Testing and validation [Informative]

contract tests for OC-1/OC-2; monotonicity suite; fairness-cap simulation; SLA backtests; explainability conformance (required fields present).

Deployment and lifecycle [Informative]

canary on weight changes; HPA on queue ingests; SBOM + attestations; all outputs signed.

References / Standards [Informative]

NIST SP 800-160 Vol. 2; NIST SP 800-53 Rev. 5 (RA-5, SI-2, PM-5); NIST CSF 2.0 (ID.RA, PR.IP); FIRST EPSS; CISA KEV; MITRE ATT&CK/D3FEND (context)

MCP-Native Protocol Specification (B7) [Normative]

- **Native Protocol(s) Consumed:** VulnFinding (Kafka/AMQP); STIX/TAXII & CISA KEV JSON; ASM Exposure (REST/GraphQL); CMDB/Business Impact (REST/GraphQL)
- **Native Protocol(s) Produced:** RemediationQueue (Kafka/AMQP/REST); PrioritizationReport (REST)
- **MCP Context Fields:**
 - **Required:** mission_id; role="RiskPrioritizationAgent"; intent="prioritize"; policy_refs; decision_basis (feature_weights, evidence_refs, explanation_ref); provenance (SPIFFE ID, KID, attestation)
 - **Optional:** constraints (sla_days, fairness_cap_per_team, region); classification; legal_hold
- **Enforcement Note:** Consumers MUST validate provenance and honor SLA/fairness annotations; any override MUST be logged with approver identity and rationale.
- **Versioning and compatibility; producers/consumers registry:** authoritative here; accept ranges per Schema Capsules.
- **Example payloads:** native and MCP-wrapped (authoritative).
- **Transparency hooks:** classification_label, provenance.attestation, decision_rationale_url exposed to downstream UIs/APIs.

Conformance: This section is [Normative] and, together with each **Schema Capsule**, defines testable requirements.

